Universidad del Desarrollo

Seguridad y Protección de Datos – Proyecto Integrador

Actividad N°5

Consentimiento, derechos de los titulares, auditoría y respuesta a incidentes

Caso 1: NortiShop (comercio electrónico)

Integrantes: Ignacia Castillo, Milan Kurte, Francisco Polo

Fecha: 28/10/2026

Repositorio: github.com/m1lvn/nortishop-seguridad (rama actividad5)

Índice

1. Introducción **3**
1.1 Alcance y normativa aplicable 3
1.2 Qué cambió en el sistema 3
2. Módulo de gestión del consentimiento **5**
2.1 Finalidades y base legal 5
2.2 Modelo de datos 5
2.3 Estados y versiones 6
2.4 Revocación y su efecto en los procesos 6
2.5 Por qué una finalidad no habilita otra 6
2.6 Trazabilidad sin datos innecesarios 7
2.7 Menores de edad: por qué el flujo no aplica 7
2.8 Interfaces y pruebas 8
3. Ejercicio de derechos **11**
3.1 Flujo de las solicitudes 11
3.2 Verificación de identidad proporcional al riesgo 11
3.3 Acceso y portabilidad 12
3.4 Rectificación 12
3.5 Supresión 12
3.6 Autorización 13
4. Registro de auditoría **19**
4.1 Eventos registrados 19
4.2 Atributos de cada registro 19
4.3 Información que no se registra 20
4.4 Protección de los registros 20
4.5 Quién puede consultar 20
4.6 Conservación y eliminación segura 20
4.7 Equilibrio entre trazabilidad y minimización 21
4.8 Eventos generados en operaciones reales de prueba 21
5. Plan de respuesta a incidentes **23**
5.1 Preparación 23
5.2 Detección y análisis 23
5.3 Contención 24
5.4 Erradicación y recuperación 25
5.5 Notificación y comunicación 25
5.6 Lecciones aprendidas 26
5.7 Escalamiento y cierre 26
5.8 Responsables por fase 27
5.9 Ejecución del plan en el sistema 27
6. Implementación en el código **32**
6.1 Decisiones de implementación 32
6.2 Integración con los módulos existentes 32
6.3 Los controles no se pueden eludir 32
6.4 Limitaciones 34
7. Evidencias de pruebas **35**
8. Justificación técnica final **40**
8.1 Principales decisiones 40
8.2 Riesgos mitigados 40
8.3 Limitaciones y trabajo pendiente 40
9. Referencias **41**
Anexo A. Cumplimiento de la pauta **42**

1. Introducción

NortiShop es una tienda de comercio electrónico. Las personas compran con una cuenta o como invitados, pagan con tarjeta a través de una pasarela de pago y reciben sus pedidos por despacho. En las actividades anteriores identificamos los datos personales que trata la tienda (Actividad N°1 e informe de inventario), los protegimos con hashing, cifrado y tokenización (Actividad N°2) y rediseñamos la base de datos con minimización, seudonimización y control de acceso por roles (Actividad N°4).

En esta actividad agregamos lo que faltaba para que los titulares puedan ejercer control sobre sus datos y para que la tienda pueda demostrar qué hizo con ellos: un módulo de consentimiento por finalidad, el ejercicio de los derechos de acceso, portabilidad, rectificación y supresión, una bitácora de auditoría protegida y un plan de respuesta a incidentes. Todo está implementado en el código del repositorio y se puede usar desde una interfaz web y desde una API. Las dos llaman a las mismas funciones de servicio, de modo que los controles se aplican igual sin importar por dónde llegue la solicitud.

1.1 Alcance y normativa aplicable

Analizamos el caso con la Ley N° 19.628 modificada por la Ley N° 21.719, que regula la protección y el tratamiento de los datos personales y crea la Agencia de Protección de Datos Personales. Según su artículo primero transitorio, las modificaciones entran en vigencia el primer día del mes vigésimo cuarto posterior a su publicación, es decir, el 1 de diciembre de 2026. El Gobierno ingresó al Senado el proyecto del boletín N° 18.623-07, que posterga esa fecha al 1 de diciembre de 2027. Al 27 de octubre de 2026 el proyecto seguía en primer trámite constitucional, con informes de las comisiones de Constitución y de Hacienda y urgencia de discusión inmediata, pero no era ley. Por eso diseñamos con la fecha vigente: NortiShop debe estar preparada para diciembre de 2026.

Los artículos que más usamos son: el 12 (consentimiento libre, informado, específico, previo, inequívoco y revocable), los artículos 5° a 9° (acceso, rectificación, supresión, oposición y portabilidad), el 11 (procedimiento y plazo de respuesta), el 14 quinquies (medidas de seguridad), el 14 sexies (reporte de vulneraciones) y el 16 quáter (niños, niñas y adolescentes). También revisamos la Ley N° 21.663, Marco de Ciberseguridad: se aplica a los servicios esenciales y a los operadores de importancia vital (art. 4°). Una tienda en línea no está en esa lista, así que sus plazos de reporte al CSIRT Nacional no rigen para NortiShop, aunque sí para su pasarela de pago ("banca, servicios financieros y medios de pago"). El plan de incidentes considera esa diferencia.

1.2 Qué cambió en el sistema

El repositorio tenía la versión de la Actividad 2 del archivo principal `nortishop.py`, porque la versión de la Actividad 4 no se había subido. Lo reconstruimos a partir de las pruebas, los scripts y el informe técnico de la Actividad 4, y las 26 pruebas de esa actividad vuelven a pasar. Sobre esa base agregamos los módulos de la Tabla 1.

Tabla 1. Módulos nuevos o modificados en la Actividad 5.

Módulo	Qué implementa
consentimiento.py	Finalidades, textos versionados, historial solo de agregar, otorgar y revocar con efecto en los procesos.

Módulo	Qué implementa
derechos.py	Solicitudes de acceso, portabilidad, rectificación y supresión con flujo de estados, plazos y verificación de identidad.
auditoria.py	Único punto de escritura de la bitácora: categoría, canal, IP truncada y cadena HMAC.
deteccion.py	Reglas sobre la bitácora que generan alertas.
incidentes.py	Fases del incidente, contención, preservación de evidencia, recifrado, comprobaciones y borrador de notificación.
sesiones.py	Sesiones con token aleatorio; en la base solo queda su SHA-256. Se pueden revocar.
rbac.py	Roles nuevos privacidad y seguridad; cada sesión se valida contra la base (cuenta habilitada, rol vigente, permiso no suspendido).
app.py, templates/, static/	Interfaz web (cookie segura y token anti-CSRF) y API JSON /api/v1 (solo token Bearer).
notificador.py	Correo simulado: buzón en memoria, porque el proyecto no tiene servidor de correo.
db.py	Tablas nuevas, restricciones CHECK y triggers que protegen el historial de consentimientos y la bitácora.

2. Módulo de gestión del consentimiento

El consentimiento es solo una de las bases de licitud. Antes de diseñar el módulo separamos qué tratamientos lo necesitan y cuáles no. Comprar, despachar y emitir la boleta se basan en el contrato de compraventa y en obligaciones legales: no tiene sentido pedir un consentimiento que la persona no podría negar sin dejar de comprar, porque ese consentimiento no sería libre. El consentimiento se pide solo para los usos opcionales.

2.1 Finalidades y base legal

Tabla 2. Finalidades registradas en la tabla finalidades.

Código	Descripción	Base legal	¿Consentimiento?
compra	Procesar la compra, el pago, el despacho y la boleta	Ejecución del contrato de compraventa	No
boletin	Enviar el boletín con novedades y ofertas por correo	Consentimiento	Sí
analitica_comportamiento	Analizar las categorías que compra el cliente (bajo seudónimo)	Consentimiento	Sí
ofertas_personalizadas	Mostrar ofertas personalizadas en la cuenta según sus compras	Consentimiento	Sí

Si alguien intenta "consentir" la finalidad `compra`, el sistema lo rechaza con el mensaje "Esta finalidad no se basa en el consentimiento". Así no queda en el historial un consentimiento que no es la base real del tratamiento.

2.2 Modelo de datos

El módulo usa tres tablas. `textos_consentimiento` guarda cada versión del texto que se le muestra a la persona, con el SHA-256 del texto: así se puede probar qué se informó exactamente, aunque el texto cambie después. `consentimientos` es el historial: cada fila es un evento (otorgado o revocado) y nunca se modifica. El estado actual no se guarda en una columna aparte, sino que se calcula a partir del último evento de cada titular y finalidad. Con una columna de estado separada, habría dos fuentes de verdad que podrían contradecirse.

Tabla 3. Tabla consentimientos (historial).

Columna	Contenido
id	Identificador del evento
titular_tipo	cliente, suscriptor (boletín sin cuenta) o seudonimo (tras la supresión)
titular_ref	Id interno del cliente, índice HMAC del correo del suscriptor o seudónimo. Nunca el correo ni el nombre
finalidad	Código de la finalidad (llave foránea a finalidades)
version	Versión del texto aceptado (llave foránea compuesta a textos_consentimiento)
accion	otorgado o revocado (CHECK)
fecha	Fecha y hora UTC del otorgamiento o de la revocación
canal	web, api o enlace_correo (baja del boletín desde el correo)

Tabla 4. Tabla textos_consentimiento.

Columna	Contenido
finalidad, version	Llave primaria compuesta
texto	Texto exacto que se muestra junto a la casilla
texto_hash	SHA-256 del texto
cambio_material	1 si el cambio altera lo que se autoriza; obliga a volver a consentir
vigente_desde	Fecha de publicación de la versión

2.3 Estados y versiones

Para cada finalidad, `estado_cliente` devuelve uno de cuatro estados: **sin_registro** (nunca se pidió o la persona no marcó la casilla), **otorgado**, **revocado** y **requiere_renovacion**. El último aparece cuando el rol privacidad publica una versión nueva del texto marcada como cambio material: el consentimiento anterior deja de valer y la función `vigente` responde falso hasta que la persona acepte la nueva versión. Un cambio menor (redacción, sin cambiar lo que se autoriza) crea una versión nueva sin exigir renovación. Al otorgar, la versión enviada debe ser la vigente. Si no lo es, se rechaza ("El texto aceptado no corresponde a la versión vigente"), para que no quede registrado un texto que la persona no vio.

2.4 Revocación y su efecto en los procesos

La revocación se hace desde la misma pantalla de consentimientos, con un solo botón, o con el enlace de baja del correo del boletín. Así se cumple que los medios de revocación sean similares a los de otorgamiento y estén siempre disponibles (art. 12). Queda como un evento nuevo con su fecha y hora. No es retroactiva: lo tratado antes de revocar no se vuelve ilícito, pero desde ese momento cada proceso deja de usar los datos.

Tabla 5. Efecto inmediato de la revocación en cada proceso.

Finalidad	Qué pasa al revocar	Dónde se comprueba
boletin	Se borra la fila de boletin_suscriptores. El envío del boletín filtra además por consentimiento vigente, así que, aunque quedara una fila, no se enviaría.	correos_para_envio_boletin
analitica_comportamiento	Se borra el registro de comportamiento_compra del seudónimo y no se guardan compras nuevas.	guardar_comportamiento devuelve False
ofertas_personalizadas	La cuenta vuelve a mostrar las ofertas generales.	ofertas(sesion)

2.5 Por qué una finalidad no habilita otra

Cada proceso pregunta por su finalidad por nombre exacto: `vigente(titular, "boletin")`. No existe una casilla "aceptar todo", ni una jerarquía en que una finalidad incluya a otra, ni un valor por defecto: si no hay un evento "otorgado" para esa finalidad exacta, la respuesta es no. En el registro las tres casillas vienen desmarcadas y cada una tiene su propio texto. La prueba C02 lo verifica: con analitica_comportamiento otorgada, ofertas_personalizadas sigue sin consentimiento y la cuenta muestra solo las ofertas generales.

2.6 Trazabilidad sin datos innecesarios

- El historial identifica al titular por su id interno, no por su correo o nombre. Para un suscriptor sin cuenta se usa el índice HMAC del correo.
- No se guarda la IP ni el navegador en el historial: para probar el consentimiento basta con la fecha, la versión (con su hash) y el canal.
- Dos triggers impiden modificar o borrar filas (`consentimientos_sin_update` y `consentimientos_sin_delete`). La única actualización permitida es reemplazar la referencia del titular por un seudónimo cuando se suprime la cuenta.
- El historial seudonimizado se conserva 2 años como prueba de licitud; después el trigger permite borrarlo.

2.7 Menores de edad: por qué el flujo no aplica

El artículo 16 quáter exige el consentimiento de los padres o representantes para tratar datos de niños y niñas (menores de 14 años) y regula el caso de los adolescentes (14 a 17 años). NortiShop decidió no crear cuentas para menores de 18 años, por tres razones:

- Comprar requiere capacidad para celebrar el contrato y un medio de pago propio: tarjetas de crédito o débito a nombre del titular.
- La tienda no ofrece productos ni contenidos dirigidos a menores, así que no tiene una necesidad legítima de tratar sus datos.
- Un flujo con representante legal obligaría a reunir datos del adulto y verificar el parentesco. Eso significa más datos personales para un caso que la tienda no busca atender.

Por eso el registro exige marcar "Declaro ser mayor de 18 años" (`declara_mayor_edad=True`). Se guarda solo la fecha de la declaración (`mayoria_edad_declarada`), no la fecha de nacimiento, que sería un dato adicional innecesario. Si a pesar de esto se detecta que una cuenta pertenece a un menor (por un reclamo o por un representante), el rol privacidad deshabilita la cuenta y suprime sus datos con el mismo flujo de supresión de la sección 3.5, sin esperar una solicitud.

2.8 Interfaces y pruebas

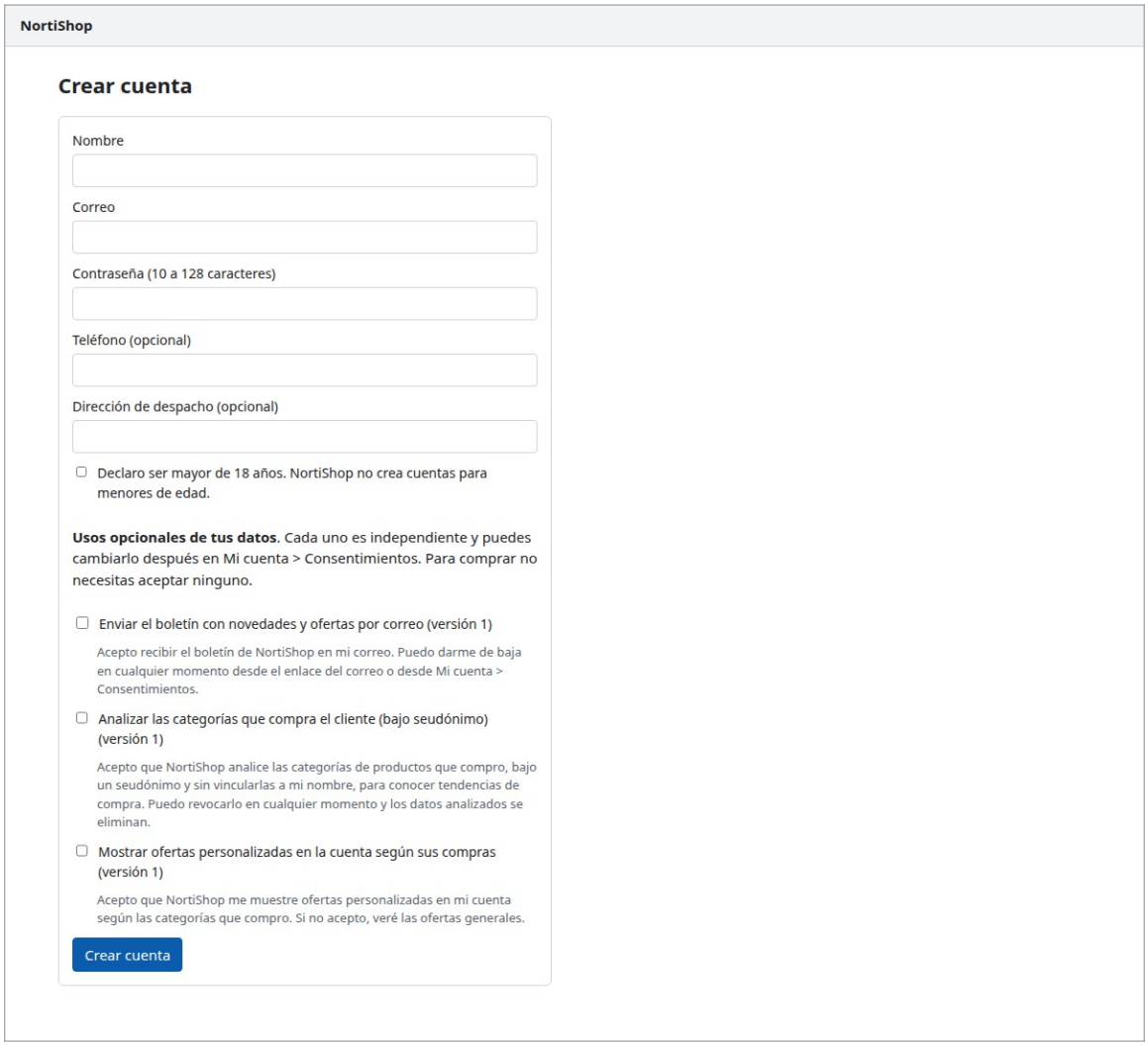


Figura 1. Registro: declaración de mayoría de edad y una casilla independiente por finalidad, desmarcada, con su texto y versión.

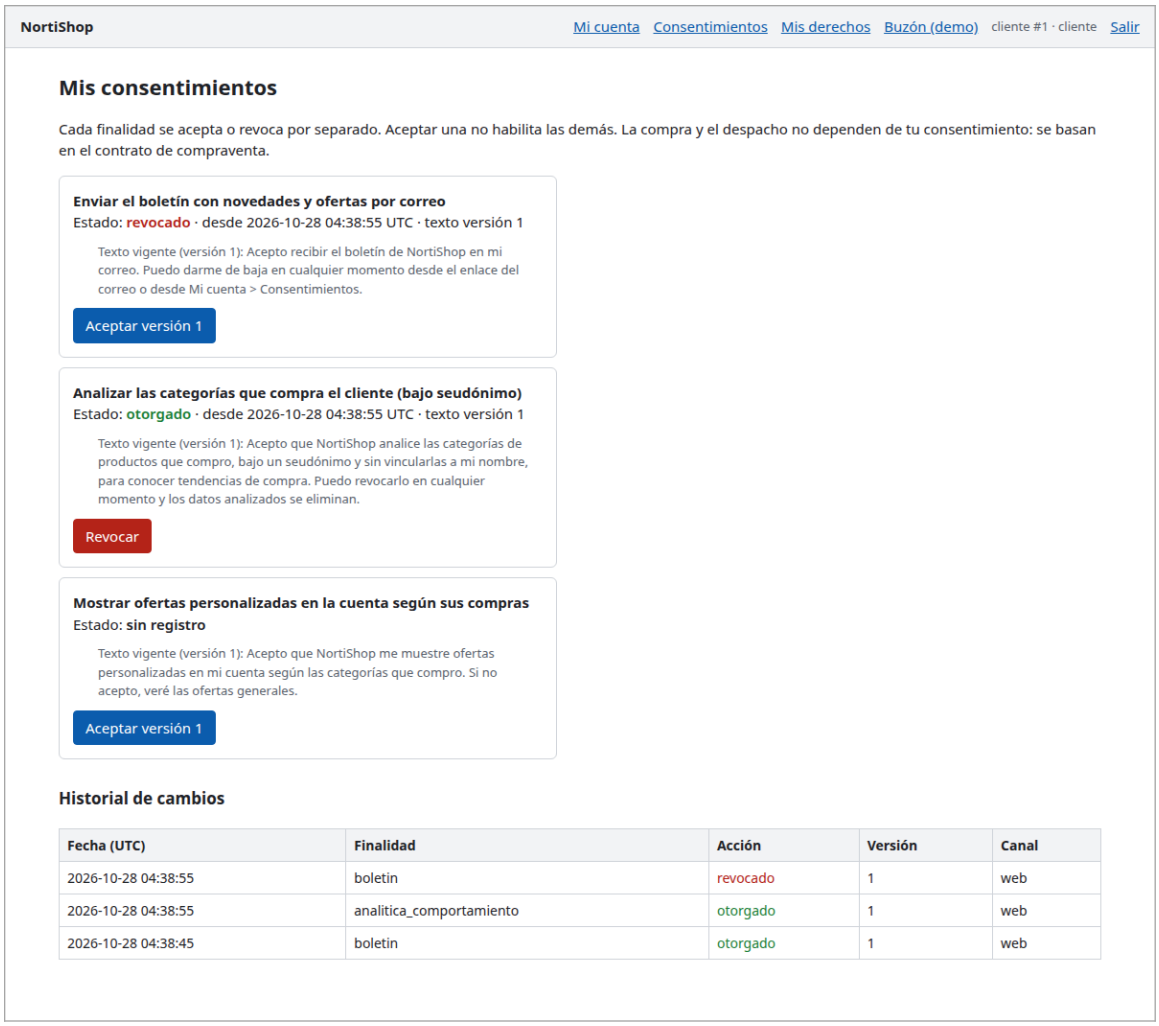


Figura 2. Mi cuenta > Consentimientos después de revocar el boletín y otorgar la analítica: estado, fecha, versión e historial de cambios.

La Figura 1 muestra el registro y la Figura 2 la pantalla donde la persona consulta y cambia sus consentimientos. La Figura 3 es la salida de `evidencia_act5.py`: registro, independencia entre finalidades, revocación con su efecto, versión nueva del texto y los intentos de modificar el historial directamente en la base.

```
Una finalidad no habilita otra:
  Ana otorga analitica_comportamiento (v1)                  -> OK 1
  vigente(analitica_comportamiento) = True
  vigente(ofertas_personalizadas)   = False
  ofertas() personalizadas          = False
  Ana otorga una versión que no se le mostró (v7)           -> ValueError: El texto aceptado no
corresponde a la versión vigente
  Ana 'consiente' la finalidad contractual 'compra'         -> ValueError: Esta finalidad no se basa
en el consentimiento

Revocación y su efecto en los procesos:
  guardar_comportamiento (con consentimiento)               -> OK True
  filas en comportamiento_compra    = 1
  boletín: ana en la campaña       = True
  Ana revoca analitica_comportamiento                       -> OK
  Ana revoca boletin                                        -> OK
  filas en comportamiento_compra    = 0
  guardar_comportamiento (revocado)                         -> OK False
  boletín: ana en la campaña       = False
```

```
Nueva versión del texto con cambio material:
  privacidad publica v2 (cambio menor)                      -> OK 2
  privacidad publica v3 (cambio material)                   -> OK 3
  finalidad | estado              | version | version_vigente
  ----------+---------------------+---------+---------------
  boletin   | requiere_renovacion | 1       | 3
  marketing publica un texto                                -> AccesoDenegado: Acceso denegado

Intentos de modificar el historial directamente en la base:
  UPDATE consentimientos SET accion='otorgado' WHERE id=2    -> IntegrityError: el historial de
consentimientos no se modifica
  DELETE FROM consentimientos WHERE id=1                     -> IntegrityError: el historial de
consentimientos no se borra
```

Figura 3. Extracto de evidencia/ev_act5_consentimiento.txt (operaciones reales sobre una base de prueba).

3. Ejercicio de derechos

Los derechos se piden desde "Mis derechos" (o por la API). Ninguno es un botón que actúe de inmediato: toda solicitud pasa por el mismo flujo, con verificación de identidad, reglas de negocio y registro en la bitácora.

3.1 Flujo de las solicitudes

Tabla 6. Estados de una solicitud (tabla solicitudes_derechos).

Estado	Qué significa	Fecha que se registra
recibida	La persona creó la solicitud reingresando su contraseña. Se envía un código al correo registrado.	fecha_recepcion, plazo_vence (+30 días)
verificada	El código del correo fue correcto.	fecha_verificacion
en_evaluacion	Se revisan las reglas del derecho pedido. La supresión la evalúa una persona del rol privacidad.	fecha_evaluacion
ejecutada / rechazada	Se entregó la copia, se rectificó o suprimió, o se rechazó con un fundamento escrito.	fecha_respuesta, resultado
cerrada	La solicitud terminó. No admite más cambios.	fecha_cierre

Las transiciones están definidas en una máquina de estados: no se puede, por ejemplo, exportar una solicitud que no está verificada, ni volver a ejecutar una cerrada. Además, la columna `estado` tiene un CHECK, así que la base rechaza valores fuera de la lista.

El plazo sigue el artículo 11: el responsable debe pronunciarse dentro de 30 días corridos desde el ingreso, prorrogables por una sola vez hasta por 30 días corridos. `plazo_vence` se calcula al recibir la solicitud y la bandeja de privacidad muestra los días restantes. `prorrogar` solo funciona una vez y exige un motivo. Cuando se rechaza, la respuesta indica la causa y recuerda que el titular tiene 30 días hábiles para reclamar ante la Agencia, como exige el mismo artículo.

3.2 Verificación de identidad proporcional al riesgo

La persona ya inició sesión, pero eso no basta: una sesión abierta en un computador compartido o robada permitiría llevarse todos los datos. Por eso se piden dos factores que la persona ya tiene, sin solicitarle documentos ni datos nuevos:

1. Reingresar la contraseña al crear la solicitud.
2. Un código de 6 dígitos enviado al correo registrado. En la base se guarda solo su HMAC; vence en 10 minutos, admite 3 intentos y se puede reenviar hasta 3 veces. Si se agotan los intentos, la solicitud se rechaza.

Para cambiar el correo se pide además un segundo código enviado al correo nuevo, para comprobar que la persona lo controla. No pedimos copia de la cédula: la tienda nunca tuvo ese dato, así que no tendría con qué compararlo, y pedirlo sería recolectar un dato adicional solo para verificar.

Limitación: el proyecto no tiene servidor de correo. `notificador.py` simula el envío con un buzón en memoria. La lógica es la misma que con un correo real; en el modo demostración, la página "Buzón (demo)" permite leer el código (Figura 5).

3.3 Acceso y portabilidad

Después de verificar, la persona descarga un JSON con formato `nortishop-export/1.0`. Es estructurado, legible por máquinas y de uso común, como pide el artículo 9° para la portabilidad. Contiene la cuenta, las tarjetas guardadas (solo marca y últimos 4 dígitos), los pedidos con sus productos y el historial de consentimientos. La solicitud de acceso agrega `informacion_tratamiento`: finalidades y base legal, destinatarios y plazos de conservación, que es la información del artículo 5°. El archivo se genera en el momento, se entrega una sola vez y no queda guardado en el servidor.

Quedan fuera: el hash de la contraseña, los tokens de la pasarela, el índice HMAC del correo, el seudónimo, los contadores de bloqueo, la bitácora de auditoría y los datos de otras personas (por ejemplo, los de un invitado que compró con otro correo). La prueba D04 y la evidencia lo comprueban buscando cada uno de esos valores dentro del archivo exportado.

3.4 Rectificación

- **Lista blanca:** solo se pueden corregir nombre, teléfono, dirección y correo. Si llega otro campo (por ejemplo `rol` o `nortipuntos`), la solicitud se rechaza completa.
- **Validación:** cada valor pasa por las mismas funciones `validar_*` del registro, así que un teléfono o correo mal formado no se guarda.
- **Valores en tránsito:** mientras la solicitud espera la verificación, los valores nuevos quedan cifrados en `detalle_cifrado`.
- **Otros módulos:** la dirección nueva se copia a los pedidos pagados que aún no se despachan. Los despachados conservan la dirección a la que efectivamente se enviaron. Si cambia el correo, se recalcula su índice HMAC, se vuelven a cifrar el teléfono y la dirección (su cifrado está amarrado al índice) y se actualiza la suscripción al boletín.
- **Trazabilidad:** en la bitácora queda qué campos cambiaron (`campos=direccion,telefono`), nunca el valor anterior ni el nuevo.

3.5 Supresión

El artículo 7° permite negar la supresión cuando el tratamiento es necesario para cumplir una obligación legal o ejecutar un contrato con el titular. Aplicamos esas excepciones así:

Tabla 7. Condiciones de la supresión.

Situación	Decisión	Fundamento
Pedidos pagados o despachados	Se rechaza con fundamento; puede volver a pedirla cuando se entreguen	Ejecución del contrato (art. 7° ii)
Sin pedidos en curso	Pasa a evaluación del rol privacidad, que aprueba o rechaza con fundamento	—
Pedidos entregados	Se conservan solo los datos contables (código, monto, fecha), sin vínculo con la persona ni dirección	Obligación tributaria: el SII puede revisar hasta 3 años, o 6 en ciertos casos (art. 200 del Código Tributario)
Historial de consentimientos	Se seudonimiza y se borra a los 2 años	Prueba de licitud del tratamiento pasado

Al aprobar, `suprimir_cliente` borra la cuenta, las tarjetas guardadas (y pide a la pasarela borrar los tokens), el registro de comportamiento y la suscripción al boletín, y revoca las sesiones abiertas. Lo borrado se sobrescribe en el archivo (`secure_delete`), así que tampoco queda en páginas libres de la base. Así ningún proceso puede seguir usando esos datos, porque ya no existen y los procesos con consentimiento consultan uno que ya no está vigente.

Copias de respaldo: no se puede editar cada respaldo, así que se usa una lista de supresión con el índice HMAC del correo (no el correo). Si se restaura un respaldo, `reaplicar_supresiones` vuelve a suprimir esas cuentas antes de abrir el servicio (prueba D12). Los respaldos rotan, y con eso los datos desaparecen también de las copias. Sistemas relacionados: la pasarela borra el token; la empresa de despacho solo recibió la dirección de pedidos ya entregados, que la tienda no puede borrar en sus sistemas. Por eso el art. 11 obliga a comunicarle la supresión, lo que queda como tarea del contrato con ese proveedor.

3.6 Autorización

Cada función de servicio tiene el decorador `@requiere_permiso`, con una regla de propiedad: un cliente solo puede actuar sobre sus propias solicitudes (prueba D05). La bandeja de privacidad identifica al titular con un seudónimo, sin nombre ni correo (Figura 8), porque para evaluar una solicitud no hace falta saber quién es. Soporte, logística y marketing no tienen el permiso `derechos.gestionar`.

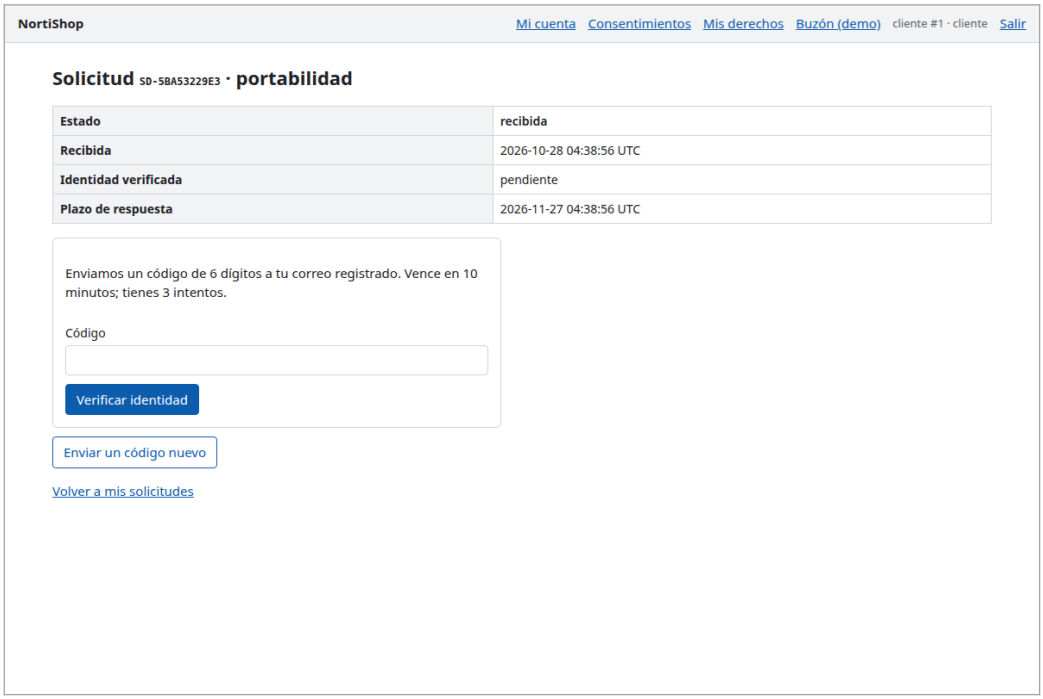


Figura 4. Solicitud de portabilidad recibida: espera el código enviado al correo.

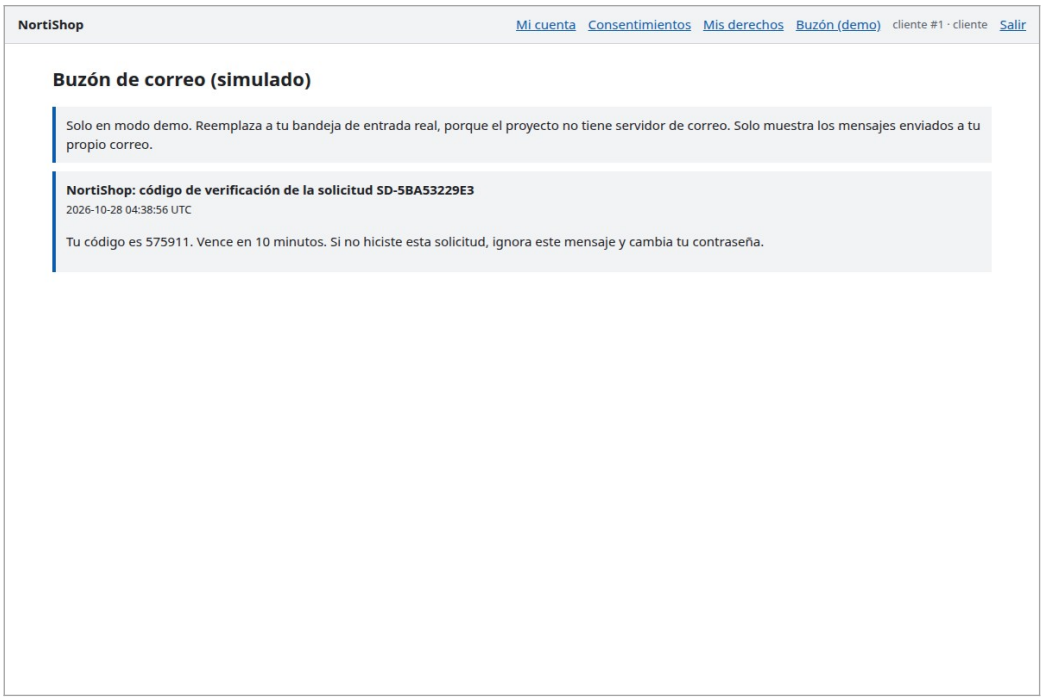


Figura 5. Buzón simulado (solo en modo demostración) con el código de un solo uso.

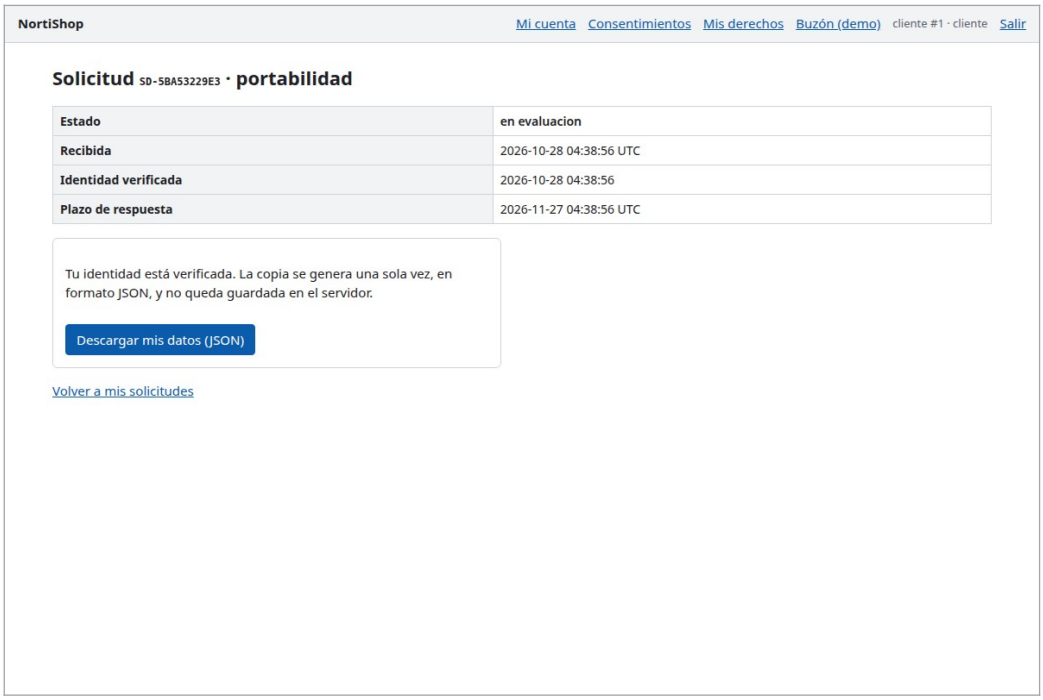


Figura 6. Identidad verificada: la copia se descarga una sola vez.

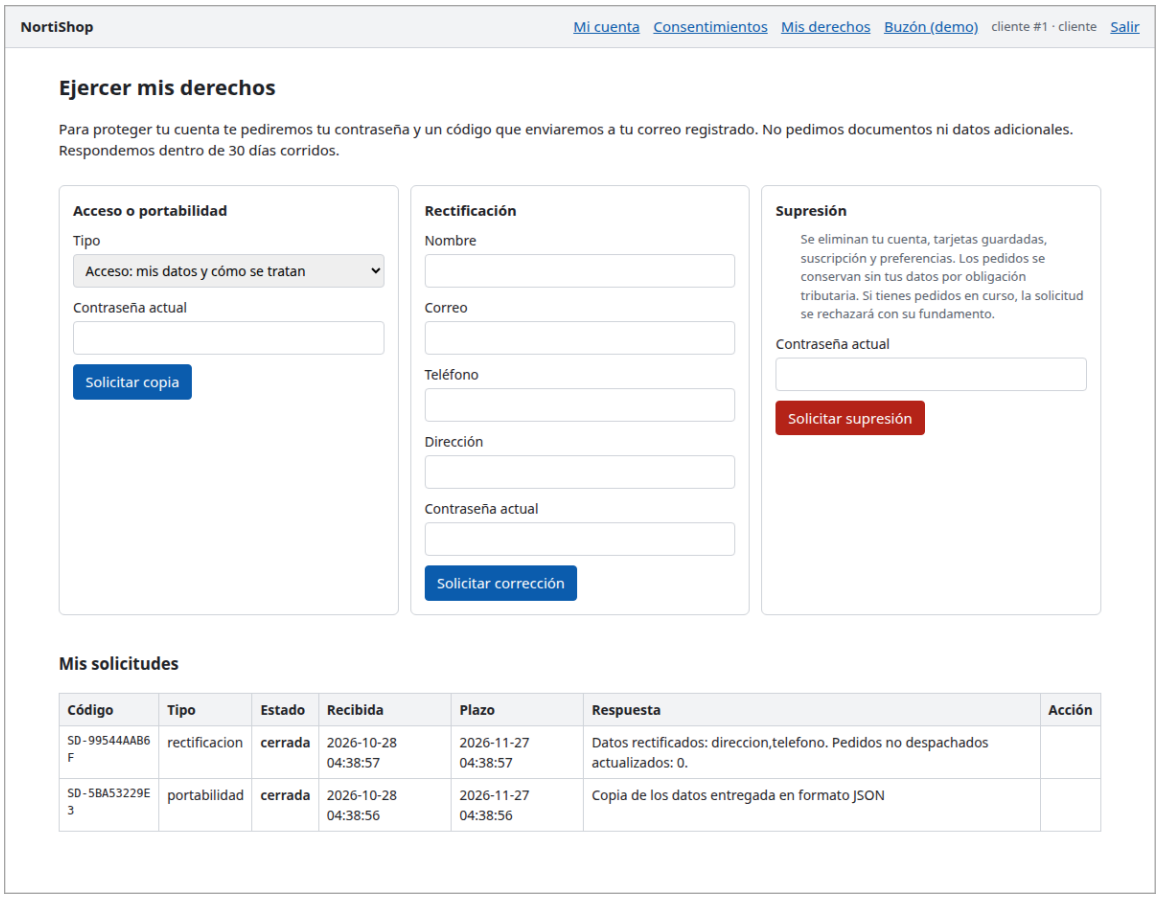


Figura 7. Mis derechos: formularios y seguimiento de las solicitudes con sus fechas y plazo.

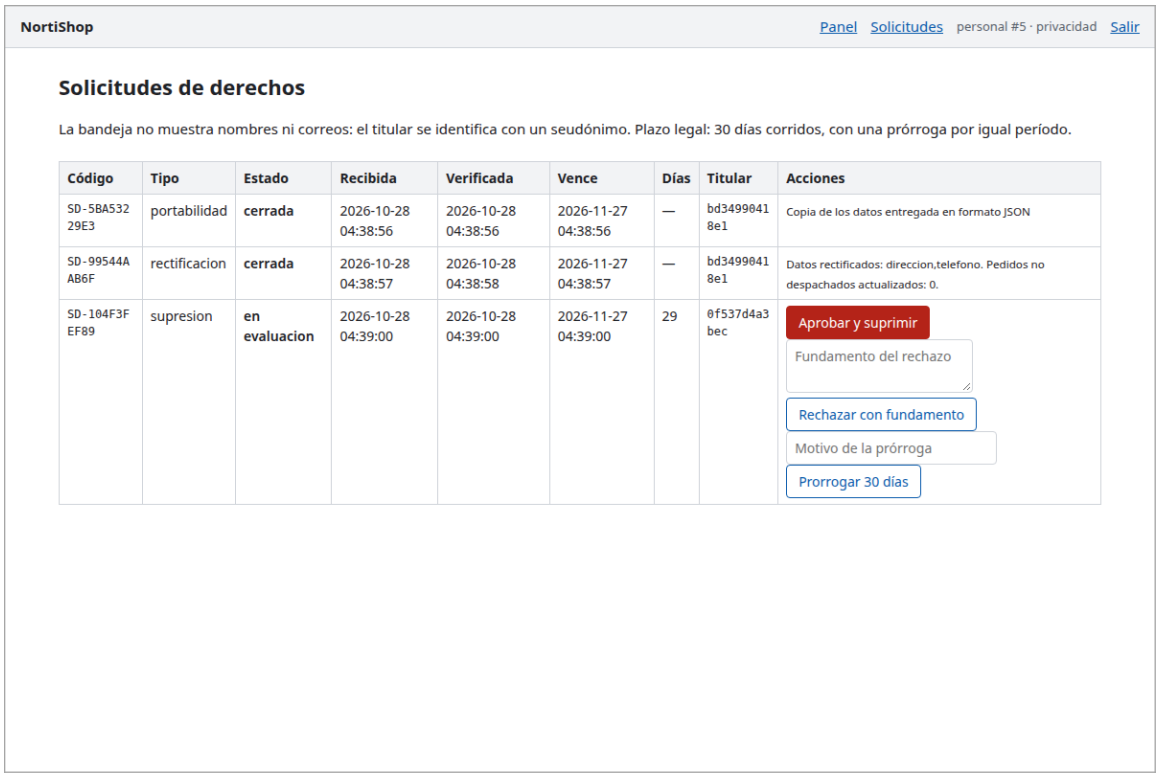


Figura 8. Bandeja del rol privacidad: titular bajo seudónimo, plazo y acciones (aprobar, rechazar con fundamento, prorrogar).

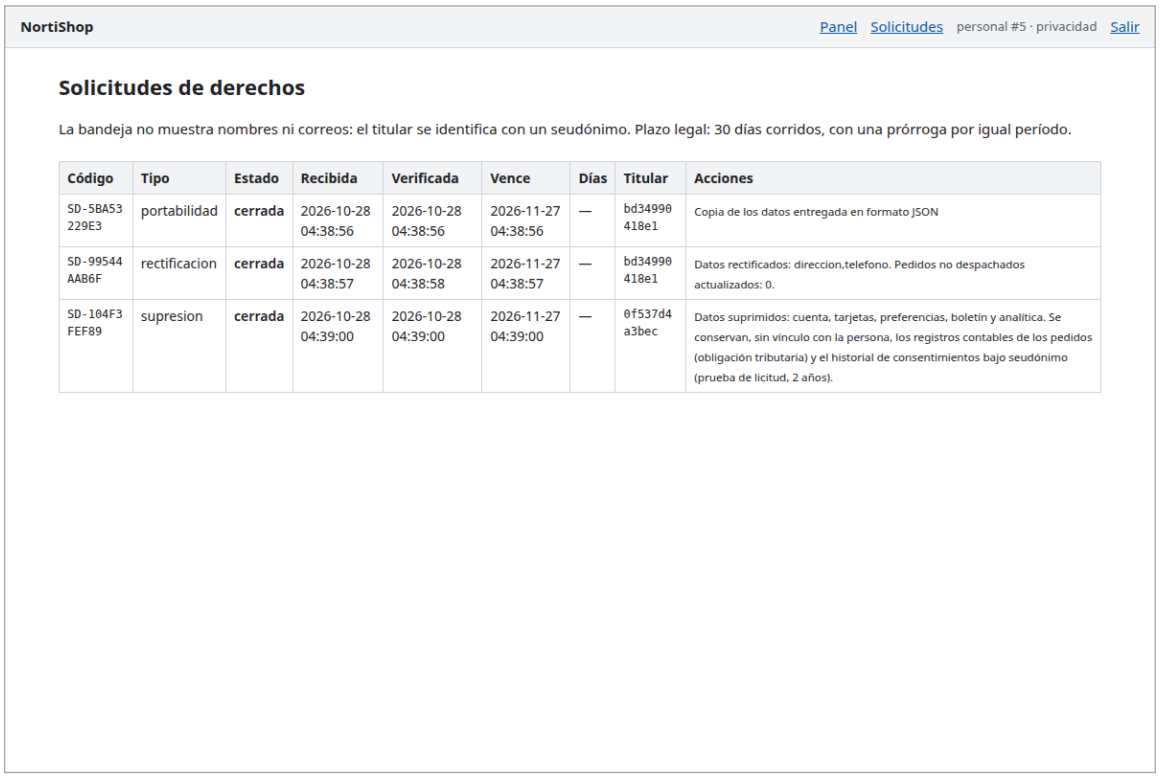


Figura 9. La misma bandeja después de aprobar la supresión.

```
a) Acceso / portabilidad
```

```
  crear_solicitud con contraseña incorrecta                -> AccesoDenegado: Acceso denegado
  crear_solicitud('portabilidad') con contraseña           -> OK SD-E1541C0E25
  correo recibido: "NortiShop: código de verificación de la solicitud SD-E1541C0E25"
  en la base solo queda el HMAC del código: cb585cace5ccb72dac9bd898...
  exportar antes de verificar                              -> ValueError: La solicitud no está lista para
exportar o ya fue respondida
  Beto intenta verificar la solicitud de Ana               -> AccesoDenegado: Acceso denegado
  verificar_identidad con código incorrecto                -> ValueError: El código es incorrecto o venció
  verificar_identidad con el código del correo             -> OK en_evaluacion
  exportar -> JSON con secciones ['formato', 'generado', 'solicitud', 'cuenta', 'tarjetas', 'pedidos',
'consentimientos'] (guardado en evidencia/ev_act5_exportacion.json)
  ¿la exportación incluye hash de contraseña? False
  ¿la exportación incluye token de pasarela? False
  ¿la exportación incluye datos del invitado? False
  ¿la exportación incluye índice HMAC del correo? False
  ¿la exportación incluye seudónimo? False
  exportar por segunda vez                                 -> ValueError: La solicitud no está lista para
exportar o ya fue respondida

b) Rectificación
  rectificar campo 'rol'                                   -> ValueError: Solo se pueden rectificar:
nombre, teléfono, dirección y correo
  rectificar teléfono con formato inválido                 -> ValueError: El campo teléfono no tiene un
formato válido
  verificar y ejecutar rectificación de teléfono y dirección -> OK cerrada
  dirección del pedido no despachado ahora: Calle Nueva 99, Ñuñoa
  verificar identidad (cambio de correo)                   -> OK en_evaluacion
  confirmar con el código enviado al correo NUEVO          -> OK cerrada
  login con el correo antiguo: None
  login con el correo nuevo:   Sesion(tipo='cliente', id=1, rol='cliente')
  teléfono tras el recifrado:  +56 9 7777 8888

c) Supresión
  supresión con un pedido en curso                         -> OK cerrada
  respuesta: Existen pedidos en curso (pagados o despachados). Sus datos se necesitan para cumplir el
contrato de compraventa y el despacho. Puede volver a solicitar la supresión cuando los pedidos se hayan
entregado.
  supresión sin pedidos en curso                           -> OK en_evaluacion
  bandeja de privacidad (sin nombres ni correos):
  codigo        | tipo      | estado        | fecha_recepcion     | plazo_vence         | dias_restantes |
titular
  --------------+-----------+---------------+---------------------+---------------------+----------------
+-------------
  SD-2D62F963BA | supresion | en_evaluacion | 2026-10-28 04:51:50 | 2026-11-27 04:51:50 | 29             |
bd34990418e1
  soporte intenta resolver la supresión                    -> AccesoDenegado: Acceso denegado
  privacidad aprueba la supresión                          -> OK cerrada
  después de la supresión:
    clientes con id de Ana:          0
    tarjetas guardadas:              0
    pedido 1 (contable):             {'codigo': 'NS-115EA17E3ADE', 'cliente_id': None, 'direccion_cifrado':
None, 'monto': 39990, 'estado': 'entregado'}
    consentimientos seudonimizados:  5
    lista de supresión (respaldos):  1 índice(s)
    login de Ana:                    None
```

Figura 10. Extracto de evidencia/ev_act5_derechos.txt: verificación, exportación, rectificación y supresión.

```
{
  "formato": "nortishop-export/1.0",
  "generado": "2026-10-28 04:51:48",
  "solicitud": "SD-E1541C0E25",
  "cuenta": {
    "nombre": "Ana Prueba",
    "correo": "ana@prueba.cl",
    "telefono": "+56 9 1111 2222",
    "direccion": "Av. Los Leones 1234, Providencia",
    "nortipuntos": 0,
    "mayoria_edad_declarada": "2026-10-28 04:51:47"
  },
  "tarjetas": [
    {
      "marca": "VISA",
      "terminacion": "1111"
    }
  ],
  "pedidos": [
    {
      "codigo": "NS-115EA17E3ADE",
      "fecha": "2026-10-28 04:51:48",
      "estado": "pagado",
```

```
      "monto": 39990,
      "tarjeta": "**** 1111",
      "region": "Metropolitana de Santiago",
      "direccion": "Av. Los Leones 1234, Providencia",
      "productos": [
        {
          "producto": "Audífonos Bluetooth",
          "cantidad": 1,
          "precio": 39990
        }
      ]
  ...
```

Figura 11. Inicio del JSON exportado (evidencia/ev_act5_exportacion.json, datos ficticios).

4. Registro de auditoría

La bitácora debe permitir reconstruir quién hizo qué, sobre qué y con qué resultado, sin convertirse en otra copia de los datos personales. Por eso registra referencias (ids internos, códigos de solicitud, nombres de campos) y no valores.

4.1 Eventos registrados

Tabla 8. Eventos por categoría.

Categoría	Eventos (operación)
autenticacion	auth.login (éxito, fallido, bloqueo), sesion.crear, sesion.cerrar
acceso	Lectura de datos personales: cuenta.propia.leer, contacto.cliente.leer, despacho.direccion.leer, etc.
consentimiento	consentimiento.otorgar, consentimiento.revocar, publicación de un texto
derechos	derechos.solicitar, derechos.verificar_identidad, derechos.gestionar (bandeja), prórroga y rechazo
exportacion	derechos.exportar
modificacion	derechos.rectificar, pedidos.estado.actualizar, otros cambios
supresion	derechos.suprimir, cuenta.suprimir, cuenta.eliminar
administracion	roles.crear_cuenta, retencion.ejecutar, auditoria.leer, auditoria.purgar
seguridad	alertas.generar, alertas.gestionar, incidentes.*, contencion.*

Se registran tanto las operaciones permitidas como las denegadas. Una denegación aislada no dice mucho, pero varias seguidas del mismo actor son una señal de abuso (regla `denegaciones_repetidas`).

4.2 Atributos de cada registro

Tabla 9. Columnas de la tabla auditoria.

Atributo	Contenido	Ejemplo
id	Identificador correlativo del evento	77
fecha	Fecha y hora UTC	2026-10-28 04:29:52
actor_tipo, actor_id	Cuenta que actuó (cliente o personal) por id interno	personal:5
rol	Rol con el que actuó	privacidad
permiso	Operación realizada	derechos.suprimir
categoria	Clasificación para filtrar y para la detección	supresion
recurso	Recurso afectado: id o código, nunca el dato	SD-C15B5B8DE2
resultado	permitido, denegado, exito o fallido (CHECK)	exito
canal	web, api o sistema	web
origen	IP truncada a la red /24 (IPv4) o /48 (IPv6)	127.0.0.0/24
detalle	Nombres de campos, motivos o conteos; nunca valores	campos=direccion,telefono
hash_previo, hash	Encadenamiento HMAC con el registro anterior	f2d4d7bc1509…

4.3 Información que no se registra

- Contraseñas (ni siquiera la que se ingresó mal), códigos de verificación, tokens de sesión o de la pasarela y llaves criptográficas.
- Valores de datos personales: correos, nombres, teléfonos, direcciones, productos comprados. Un login fallido sobre un correo inexistente se registra sin el correo, porque podría ser el de una persona real mal escrito.
- La IP completa: se guarda solo la red, suficiente para correlacionar un ataque sin identificar a la persona.
- El contenido de una rectificación: solo qué campos cambiaron.

`verificar_secretos.py` y la prueba A01 revisan que en la bitácora no aparezcan correos, contraseñas ni otros datos personales después de ejecutar todas las operaciones.

4.4 Protección de los registros

- **Un solo punto de escritura:** solo `auditoria.registrar_evento` inserta filas. Usa una transacción BEGIN IMMEDIATE para que dos eventos simultáneos no rompan la cadena.
- **Inmutabilidad en la base:** el trigger `auditoria_sin_update` rechaza toda modificación y `auditoria_sin_delete` solo permite borrar filas con más de 2 años.
- **Cadena HMAC:** cada fila guarda HMAC-SHA256(llave de auditoría, campos + hash anterior). Quien tenga acceso al archivo y quite los triggers puede cambiar una fila, pero no puede recalcular los HMAC sin la llave `NORTISHOP_LLAVE_AUDITORIA`, que es distinta de las llaves de cifrado. `verificar_cadena` detecta filas alteradas, borradas o insertadas e indica la primera que no cuadra.
- **Ancla externa:** `ancla()` entrega el último id y hash. Guardarlo fuera del servidor permite detectar si alguien borró las últimas filas.
- **Archivo:** la base se crea con permisos 600 y la integridad se verifica también desde el panel de seguridad, que genera una alerta crítica si la cadena no cuadra.

4.5 Quién puede consultar

Solo los roles seguridad y administrador tienen `auditoria.leer`, en modo de solo lectura: no existe ninguna función que modifique registros. Cada lectura de la bitácora queda registrada como un evento más. Purgar requiere `auditoria.purgar`, que tiene solo el rol seguridad. Marketing, soporte, logística, privacidad y los clientes reciben 403 (prueba A05).

4.6 Conservación y eliminación segura

Los registros se conservan 2 años: es tiempo suficiente para investigar un incidente que se descubre tarde y para responder un reclamo ante la Agencia, cuyo plazo corre desde la respuesta del responsable. `purgar_vencidos` borra solo las filas que superan ese plazo (el trigger impide borrar las recientes) y deja un evento de purga con el último hash eliminado. Así, la cadena de lo que queda sigue siendo verificable (prueba A06). Para que lo borrado no quede recuperable en las páginas libres del archivo, toda conexión activa `PRAGMA secure_delete`: SQLite sobrescribe con ceros el contenido eliminado. Esto vale también para la supresión de cuentas y la retención. La prueba A06 comprueba que, tras la purga, el texto de los eventos borrados ya no aparece en el archivo de la base.

4.7 Equilibrio entre trazabilidad y minimización

Con ids internos y códigos se puede reconstruir cualquier operación, porque el equipo de seguridad puede cruzar el id con la base cuando lo necesita. Esa consulta queda a su vez registrada. Lo que la bitácora no permite es que alguien con acceso solo a ella conozca los datos de los clientes. Así se pierde algo de comodidad al investigar, pero si se filtra la bitácora no se filtran también los datos.

4.8 Eventos generados en operaciones reales de prueba

```
Eventos generados durante esta ejecución: 218. Por categoría:
  categoria      | resultado | eventos
  ---------------+-----------+--------
  acceso         | denegado  | 7
  acceso         | permitido | 34
  administracion | denegado  | 2
  administracion | exito     | 5
  administracion | permitido | 6
  autenticacion  | exito     | 21
  autenticacion  | fallido   | 20
  consentimiento | denegado  | 2
  consentimiento | exito     | 6
  consentimiento | permitido | 11
  derechos       | denegado  | 1
  derechos       | exito     | 10
  derechos       | fallido   | 2
  derechos       | permitido | 22
  exportacion    | exito     | 1
  modificacion   | exito     | 5
  modificacion   | permitido | 5
  seguridad      | denegado  | 2
  seguridad      | exito     | 23
  seguridad      | permitido | 31
  supresion      | exito     | 2
```

Figura 12. Cantidad de eventos por categoría y resultado tras ejecutar evidencia_act5.py.

Tabla 10. Muestra de eventos reales (evidencia/ev_act5_auditoria.txt).

Id	Hora	Actor	Operación	Recurso	Resultado	Detalle
1	04:51:44	—	auth.login	personal:1	exito	—
3	04:51:44	personal:1	roles.crear_cuenta	personal:2	exito	rol=soporte
28	04:51:47	cliente:1	consentimiento.revocar	analitica_comportamiento	exito	—
34	04:51:47	personal:5	consentimiento.textos.publicar	—	permitido	—
39	04:51:47	personal:4	consentimiento.textos.publicar	—	denegado	—
47	04:51:48	—	auth.login	cliente:1	fallido	clave_incorrecta
55	04:51:48	cliente:1	derechos.verificar_identidad	SD-E1541C0E25	fallido	codigo_incorrecto
57	04:51:48	cliente:1	derechos.verificar_identidad	SD-E1541C0E25	exito	tipo=portabilidad estado=en_evaluacion
59	04:51:48	cliente:1	derechos.exportar	SD-E1541C0E25	exito	tipo=portabilidad formato=json secciones=generado,solicitud,cuenta,tarjetas,pedidos,consentimientos
70	04:51:49	cliente:1	derechos.rectificar	SD-77EB670213	exito	cliente=1 campos=direccion,telefono pedidos_actualizados=1

Id	Hora	Actor	Operación	Recurso	Resultado	Detalle
96	04:51:50	—	cuenta.suprimir	1	exito	tarjetas=1 pedidos_desvinculados=si consentimientos=seudonimizados
116	04:51:54	personal:2	contacto.cliente.leer	2	permitido	—
162	04:51:54	personal:6	contencion.deshabilitar_cuenta	personal:2	exito	incidente=INC-20261028-72B2 sesiones=0
163	04:51:54	personal:2	contacto.cliente.leer	2	denegado	—

```
Información que NO aparece en la bitácora:
  correos               presentes: False
  contraseñas           presentes: False
  teléfonos             presentes: False
  direcciones           presentes: False
  productos comprados   presentes: False
  hash bcrypt           presentes: False
  tokens de pasarela    presentes: False

Protección de la bitácora:
  verificar_integridad -> {'ok': True, 'filas': 219, 'error_en': None}
  marketing lee la bitácora                                -> AccesoDenegado: Acceso denegado
  privacidad lee la bitácora                               -> AccesoDenegado: Acceso denegado
  soporte lee la bitácora                                  -> AccesoDenegado: Acceso denegado
  administrador purga la bitácora                          -> AccesoDenegado: Acceso denegado
  seguridad purga (nada supera los 2 años)                 -> OK 0
  UPDATE auditoria SET resultado='permitido' WHERE resultado='denegado' -> IntegrityError: auditoria
es inmutable
  DELETE FROM auditoria WHERE id=10                        -> IntegrityError: auditoria es
inmutable

Ataque con acceso al archivo (se quitan los triggers sobre una COPIA de la base):
  se cambió un 'denegado' por 'permitido' -> verificar_cadena: {'ok': False, 'filas': 225,
'error_en': 39}
```

Figura 13. Ausencia de datos personales, permisos de lectura y detección de manipulación en una copia de la base.

5. Plan de respuesta a incidentes

El plan cubre los eventos que pueden comprometer la confidencialidad, integridad o disponibilidad de los datos personales de NortiShop: acceso indebido de un empleado, robo de credenciales, filtración de la base o de las llaves, alteración de datos, abuso de la exportación y caída del servicio. Las herramientas del plan están implementadas en `deteccion.py` e `incidentes.py` y se usan desde el panel de seguridad.

5.1 Preparación

Responsables. Para este ejercicio asignamos los roles a los integrantes del grupo. En la empresa real serían cargos, con un suplente cada uno.

Tabla 11. Responsables y roles en el sistema.

Responsable	Función en el plan	Rol en el sistema
Milan Kurte	Responsable de seguridad y coordinador del incidente: clasifica, decide la contención, preserva la evidencia y cierra el caso.	seguridad
Francisco Polo	Desarrollo y administración del sistema: corrige vulnerabilidades, rota llaves, restaura respaldos y despliega.	administrador (y acceso al servidor)
Ignacia Castillo	Delegada de protección de datos y comunicación (art. 50, designación voluntaria): evalúa el riesgo para los titulares, redacta y autoriza las notificaciones y atiende consultas.	privacidad

Canales de reporte:

- Internos: alertas automáticas en el panel de seguridad; el personal reporta por el canal de seguridad del equipo y, en horario no hábil, por teléfono al responsable de seguridad.
- Externos: clientes y terceros escriben a privacidad@nortishop.cl; investigadores a seguridad@nortishop.cl.
- Proveedores: la pasarela de pago y el hosting deben avisar por contrato si sufren un incidente que afecte a la tienda.

Recursos técnicos: la bitácora encadenada, las reglas de detección, las acciones de contención con su permiso propio (`contencion.ejecutar`), `preservar_evidencia`, la rotación de llaves (`generar_llaves.py --rotar` y `rotar_llaves.py`), la lista de supresión para restaurar respaldos y el borrador de notificación. Procedimientos: este plan, la plantilla de notificación y una revisión trimestral de las reglas y los permisos.

5.2 Detección y análisis

Criterios. Las reglas se evalúan cada vez que se registra un evento en la bitácora:

Tabla 12. Reglas de detección implementadas.

Regla	Condición	Severidad
fuerza_bruta_cuenta	5 inicios de sesión fallidos sobre una cuenta en 15 minutos (la cuenta además se bloquea)	media
relleno_credenciales	Fallos sobre 10 cuentas distintas en 10 minutos	alta
exportacion_anomala	3 exportaciones del mismo titular en 24 horas	alta

Regla	Condición	Severidad
cambio_correo_y_exportacion	Cambio de correo y exportación en menos de 24 horas (señal de toma de cuenta)	alta
consulta_masiva	Una persona del personal descifra 30 contactos o direcciones en 1 hora	alta
denegaciones_repetidas	5 accesos denegados del mismo actor en 10 minutos	media
cambio_privilegios	Se crea una cuenta administrador o seguridad	media
integridad_auditoria	La cadena HMAC de la bitácora no cuadra	crítica

Otros criterios que se detectan fuera del sistema: credenciales o llaves publicadas (por ejemplo, en un repositorio), aviso de la pasarela o de un tercero, o el reclamo de un cliente.

Alerta, evento sospechoso e incidente confirmado:

- **Alerta:** la genera una regla de forma automática. No es un incidente. Mientras está abierta, los eventos nuevos del mismo tipo no generan alertas duplicadas.
- **Evento sospechoso:** una alerta que seguridad pasa a "en análisis" porque no tiene explicación evidente. Se revisa la bitácora del actor y del recurso.
- **Incidente confirmado:** hay evidencia de que la confidencialidad, integridad o disponibilidad de datos personales se vio o pudo verse afectada. Se registra con "Escalar a incidente", que crea un código INC-…, y la alerta queda vinculada. Si no hubo afectación, la alerta se descarta como falso positivo y la decisión queda en la bitácora.

Alcance y gravedad. En la evaluación se registran las categorías de datos afectadas, el número estimado de titulares, el período y si quien accedió pudo leer los datos. La severidad combina el tipo de dato y el volumen:

Tabla 13. Criterio de severidad.

Severidad	Ejemplos
baja	Intento bloqueado sin acceso a datos (fuerza bruta contenida)
media	Acceso a datos de contacto de pocos titulares; cuenta de cliente tomada
alta	Acceso indebido a datos de muchos titulares, credenciales comprometidas, historial de compras expuesto
crítica	Filtración de la base junto con las llaves, alteración de la bitácora, compromiso de una cuenta administrador o seguridad

5.3 Contención

Antes de cambiar nada, seguridad ejecuta "Preservar": `preservar_evidencia` hace una copia de la base con la API de respaldo de SQLite (consistente aunque haya escrituras), calcula su SHA-256, la deja de solo lectura (permisos 0400) y guarda un manifiesto con el ancla de la bitácora. Las acciones de contención no borran nada: deshabilitan o revocan, y cada una queda en la bitácora con el código del incidente.

Tabla 14. Acciones de contención implementadas (permiso contencion.ejecutar).

Acción	Efecto
revocar_sesiones	Invalida las sesiones de una cuenta, o todas. El token deja de servir en la web y en la API.
deshabilitar_cuenta	Bloquea el inicio de sesión de una cuenta (cliente o personal) y revoca sus sesiones. Una sesión ya cargada en memoria también deja de servir, porque cada operación revisa la cuenta en la base.
suspender_permiso	Corta una operación para todos los roles (por ejemplo, contacto.cliente.leer). Los permisos del rol seguridad no se pueden suspender, para no bloquear la respuesta.
Aislar componentes	Fuera del código: retirar la API pública o el servidor de la red, o rotar el secreto compartido con la pasarela.

5.4 Erradicación y recuperación

Erradicar es eliminar la causa: corregir la vulnerabilidad en el código con una prueba que la reproduzca, quitar permisos excesivos, cambiar las contraseñas comprometidas y, si se filtraron llaves, rotarlas. `generar_llaves.py --rotar` agrega una versión nueva de la llave y `rotar_llaves.py` vuelve a cifrar todos los datos con ella en una sola transacción. Después la llave antigua se retira del .env. Si hay que restaurar un respaldo, primero se reaplica la lista de supresión.

Antes de restablecer, `comprobar_recuperacion` revisa que la bitácora esté íntegra, que no queden valores cifrados con la llave antigua, que no haya permisos suspendidos y que no queden alertas altas o críticas sin resolver. Solo si todo se cumple marca "listo para restablecer" (Figura 17). Las cuentas deshabilitadas se informan, pero no impiden reabrir el servicio, porque una cuenta comprometida puede seguir bloqueada hasta que su dueño cambie la contraseña.

5.5 Notificación y comunicación

Criterios. El artículo 14 sexies obliga a reportar a la Agencia las vulneraciones de seguridad que causen destrucción, filtración, pérdida, alteración o acceso no autorizado a datos personales cuando exista un riesgo razonable para los derechos y libertades de los titulares. Además, hay que comunicarlo a cada titular cuando se trate de datos sensibles, datos de niños y niñas menores de 14 años o datos de obligaciones de carácter económico, financiero, bancario o comercial. Si no es posible avisar a cada uno, se publica un aviso en un medio de comunicación masivo de alcance nacional. NortiShop no trata datos sensibles ni de menores. Su caso relevante es el último: historial de compras, tarjetas y tokens de pago. `evaluar_notificacion` aplica este criterio:

Tabla 15. Decisión de notificación.

Situación	Agencia	Titulares
Solo datos cifrados y las llaves no se comprometieron	No (riesgo no razonable; se documenta)	No
Quien accedió pudo leer los datos (en claro o con las llaves) o hay credenciales	Sí	Solo si hay datos económicos
Además se afectó historial de compras, tarjeta (últimos 4) o token de pago	Sí	Sí, a cada titular

Quién evalúa y autoriza: el responsable de seguridad registra la evaluación técnica y el sistema propone la decisión. La delegada de protección de datos la revisa, ajusta el borrador y autoriza el envío. Si hay duda, se notifica.

Plazos. La Ley 21.719 no fija horas: exige reportar a la Agencia "por los medios más expeditos posibles y sin dilaciones indebidas". Como meta interna fijamos enviar el reporte dentro de 72 horas desde que el incidente se confirma, o antes si se tiene la información. Si falta información, se envía un primer reporte y se completa después. La comunicación a los titulares se hace en cuanto se conocen las medidas que pueden tomar. No asumimos un plazo universal: la Ley 21.663 fija 3 horas para la alerta temprana, 72 horas para la actualización y 15 días corridos para el informe final al CSIRT Nacional, pero solo para servicios esenciales y operadores de importancia vital. NortiShop no lo es; su pasarela de pago sí puede serlo, y por eso el contrato debe obligarla a avisar a la tienda. Además, el art. 14 sexies obliga a dejar registro de cada comunicación: naturaleza, efectos, categorías, número de titulares y medidas. El incidente guarda esos campos y la fecha de notificación.

Contenido. `borrador_notificacion` genera el texto con los siete puntos que pide la pauta, a partir de los datos del incidente:

```
Estimado/a cliente de NortiShop:
  1. Qué ocurrió: personal:2 (soporte) descifró 30 registros en 1 hora
  2. Fecha de detección: 2026-10-28 04:51:54 (UTC). Período en que ocurrió: entre 2026-10-28 09:00 y
2026-10-28 10:00.
  3. Datos personales potencialmente afectados: correo, nombre, telefono. Titulares afectados
(estimación): 30.
  4. Posibles consecuencias: uso de los datos para correos o llamadas fraudulentas (phishing) y, si
hubo credenciales, acceso no autorizado a la cuenta.
  5. Medidas adoptadas: Evidencia preservada; cuenta de soporte deshabilitada; permiso
contacto.cliente.leer suspendido; Se revisaron los permisos de soporte y se exigió MFA al personal;
Cuenta de soporte rehabilitada con contraseña nueva; permiso reactivado.
  6. Recomendaciones: cambie su contraseña de NortiShop y la de otros sitios donde use la misma;
desconfíe de mensajes que pidan datos de pago o claves; NortiShop nunca le pedirá su contraseña.
  7. Contacto para consultas y seguimiento: privacidad@nortishop.cl (indique el código INC-20261028-
72B2).
```

Figura 14. Borrador de notificación generado para el incidente de prueba (evidencia/ev_act5_deteccion_incidentes.txt).

5.6 Lecciones aprendidas

Para cerrar el caso hay que documentar las causas y las medidas correctivas y preventivas, con un mínimo de 30 caracteres. El sistema no deja cerrar sin ese texto. En la reunión de cierre se revisan tres preguntas: qué falló (causa raíz), qué control lo habría evitado o detectado antes y qué se cambia (código, permisos, umbrales de las reglas, procedimiento). Los cambios en las reglas de detección se prueban con un caso que reproduzca el incidente.

5.7 Escalamiento y cierre

- **Escalar a incidente:** cuando hay evidencia de afectación de datos personales, o cuando una alerta alta o crítica no se puede explicar en 1 hora.
- **Escalar a la delegada de protección de datos:** siempre que el incidente afecte datos personales, para evaluar la notificación.
- **Escalar a la dirección de la empresa:** severidad crítica, notificación a titulares o necesidad de detener el servicio.

- **Condiciones de cierre (verificadas por cerrar_incidente):** la evaluación de notificación está registrada; si correspondía notificar, la notificación está registrada; el incidente está en la fase de lecciones aprendidas y las lecciones están documentadas; no quedan permisos suspendidos, y la bitácora está íntegra.

5.8 Responsables por fase

Tabla 16. Responsable principal y apoyo en cada fase.

Fase	Responsable	Apoyo	Entregable
a. Preparación	Milan Kurte	Francisco Polo, Ignacia Castillo	Plan, reglas y permisos revisados cada trimestre
b. Detección y análisis	Milan Kurte	Francisco Polo	Alerta clasificada; incidente registrado con su severidad
c. Contención	Milan Kurte	Francisco Polo	Evidencia preservada; acciones registradas
d. Erradicación y recuperación	Francisco Polo	Milan Kurte	Causa corregida; comprobaciones en "listo"
e. Notificación y comunicación	Ignacia Castillo	Milan Kurte	Evaluación, reporte a la Agencia y comunicación a titulares
f. Lecciones aprendidas	Milan Kurte	Todo el equipo	Informe de cierre con causas y mejoras

5.9 Ejecución del plan en el sistema

La Figura 15 recorre el plan con un caso de prueba: un empleado de soporte descifra 30 contactos en una hora. La regla genera la alerta, seguridad la escala, preserva la evidencia, deshabilita la cuenta y suspende el permiso, evalúa la notificación, recupera y cierra.

```
Alertas generadas (una alerta no es un incidente hasta que seguridad la analiza):
  id | regla                 | severidad | descripcion
| estado
  ---+-----------------------+-----------
+-------------------------------------------------------------------------+--------
  1  | cambio_privilegios    | media     | Se creó una cuenta privilegiada (rol=seguridad)
| abierta
  2  | fuerza_bruta_cuenta   | media     | 5 intentos fallidos de inicio de sesión sobre la cuenta
cliente:2   | abierta
  3  | relleno_credenciales  | alta      | Fallos de inicio de sesión sobre 10 cuentas distintas en 10
minutos | abierta
  4  | consulta_masiva       | alta      | personal:2 (soporte) descifró 30 registros en 1 hora
| abierta
  5  | denegaciones_repetidas | media    | personal:2 acumula 5 accesos denegados en 10 minutos
| abierta
  seguridad descarta alerta de cambio de privilegios         -> OK
  seguridad escala la consulta masiva a incidente            -> OK INC-20261028-72B2

Contención (preservando evidencia primero):
  preservar_evidencia -> bd_20261028T045154Z.db sha256=edc3f99e8dab7d918348a4a2... ancla auditoría id=159
  deshabilitar cuenta personal de soporte                    -> OK
  soporte (sesión ya iniciada) lee un contacto               -> AccesoDenegado: Acceso denegado
  soporte intenta iniciar sesión                             -> None (cuenta deshabilitada)
  suspender permiso contacto.cliente.leer para todos         -> OK
  suspender un permiso del propio rol seguridad              -> ValueError: Permiso no suspendible
  administrador intenta ejecutar contención                  -> AccesoDenegado: Acceso denegado

Evaluación y decisión de notificación:
  registrar_evaluacion                                       -> OK {'notificar_agencia': True,
'notificar_titulares': False}
  criterios (evaluar_notificacion):
    ['correo'], datos legibles=False, titulares=100 -> {'notificar_agencia': False, 'notificar_titulares':
False}
```

```
    ['correo', 'telefono'], datos legibles=True, titulares=30 -> {'notificar_agencia': True,
'notificar_titulares': False}
    ['historial_compras', 'tarjeta_ultimos4'], datos legibles=True, titulares=200 -> {'notificar_agencia':
True, 'notificar_titulares': True}
    ['credenciales'], datos legibles=False, titulares=3 -> {'notificar_agencia': True,
'notificar_titulares': False}

Erradicación y recuperación:
  fase -> erradicacion
  fase -> recuperacion
  comprobaciones antes de restablecer: {'bitacora_integra': True, 'valores_con_llave_antigua': 0,
'permisos_suspendidos': ['contacto.cliente.leer'], 'cuentas_deshabilitadas': 1,
'alertas_altas_sin_resolver': 1, 'listo': False}
  comprobaciones tras rehabilitar:     {'bitacora_integra': True, 'valores_con_llave_antigua': 0,
'permisos_suspendidos': [], 'cuentas_deshabilitadas': 0, 'alertas_altas_sin_resolver': 0, 'listo': True}
```

Figura 15. Extracto de evidencia/ev_act5_deteccion_incidentes.txt: alertas, contención, evaluación y recuperación.

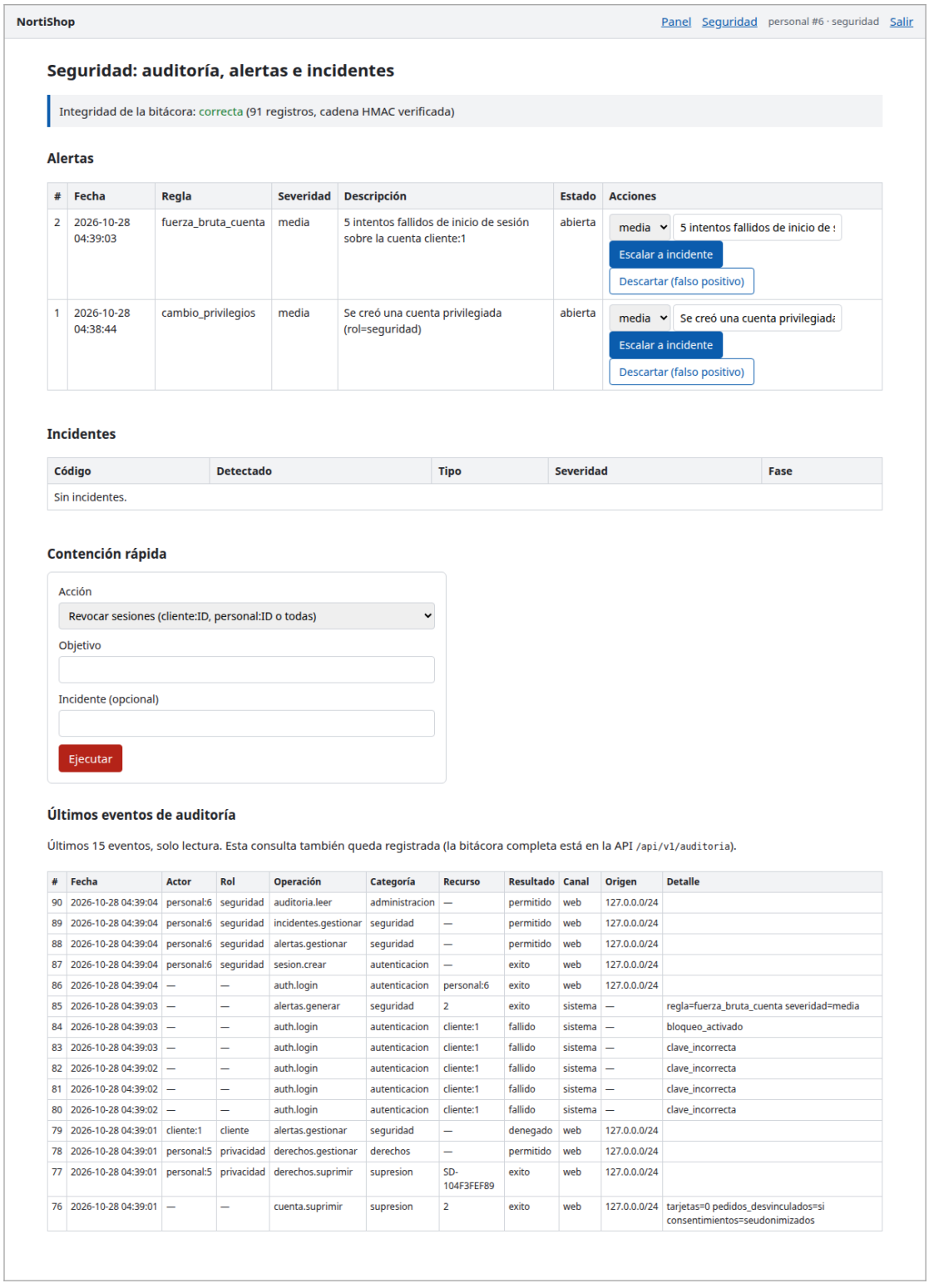


Figura 16. Panel de seguridad: integridad de la bitácora, alertas, contención rápida y últimos eventos.

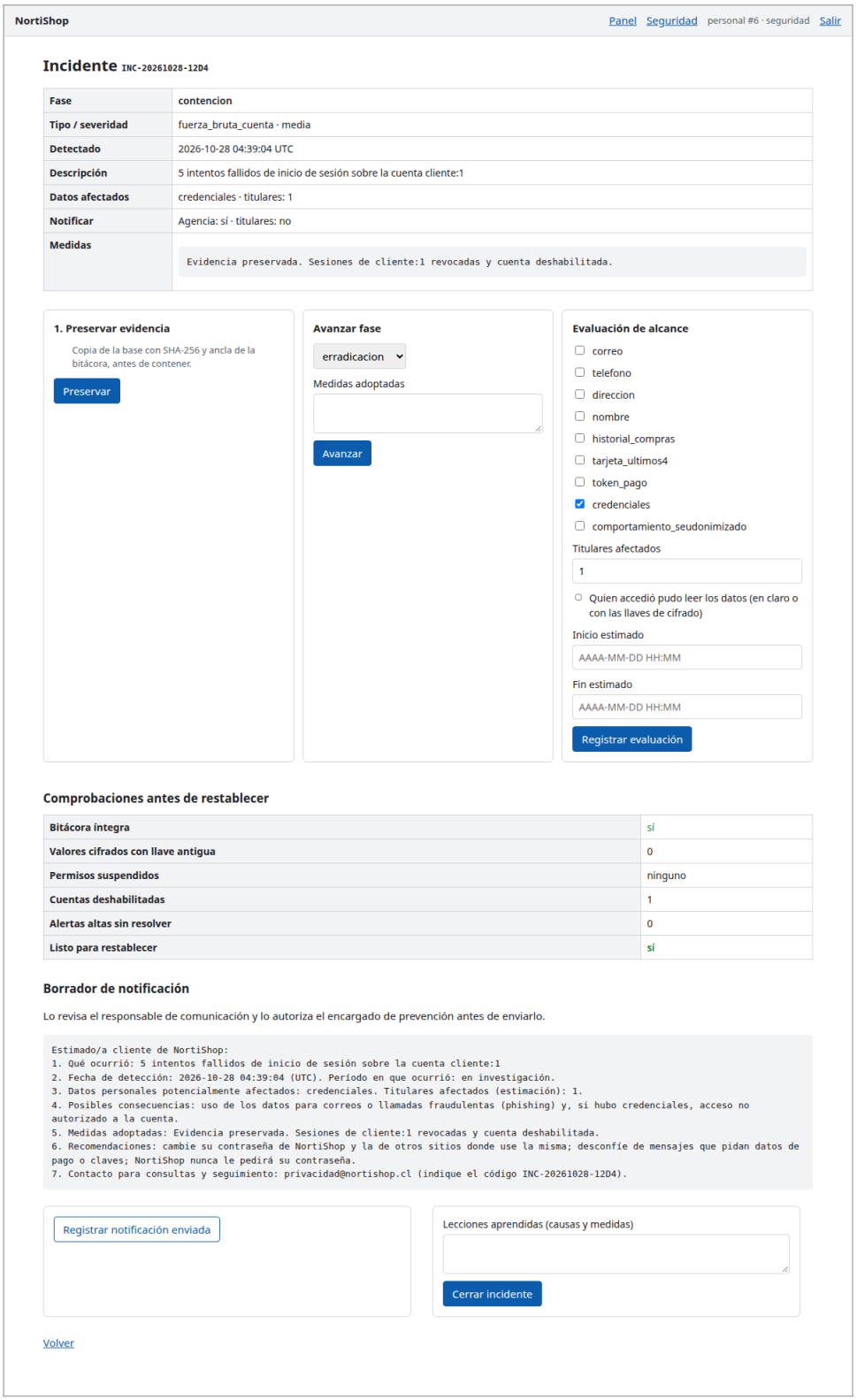


Figura 17. Ficha del incidente en contención: preservación, fases, evaluación de alcance, comprobaciones y borrador.

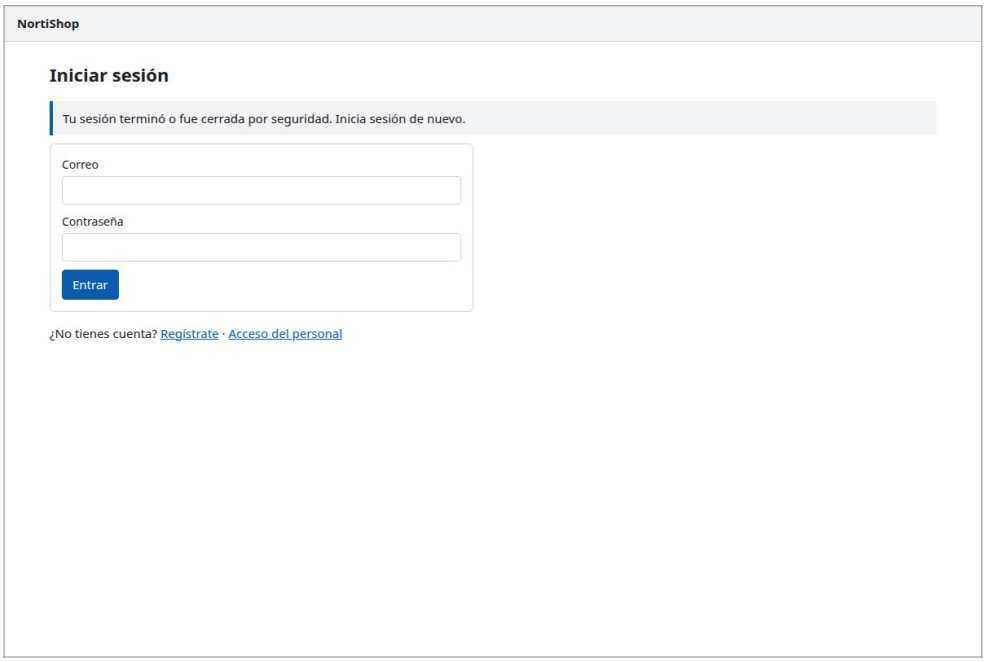


Figura 18. La cuenta de la clienta fue deshabilitada durante la contención: su sesión deja de servir.

6. Implementación en el código

6.1 Decisiones de implementación

Tabla 17. Estructuras, validaciones y controles elegidos.

Decisión	Por qué
Historial de consentimientos solo de agregar, con estado calculado	Una sola fuente de verdad y trazabilidad completa; los triggers impiden reescribir el pasado.
Texto versionado con hash	Prueba qué texto aceptó cada persona sin guardar una copia por persona.
Máquina de estados + CHECK en la base	Las solicitudes no pueden saltarse etapas, ni desde el código ni con un UPDATE directo.
Código de un solo uso guardado como HMAC	Si se filtra la base, los códigos vigentes no sirven.
Lista blanca de campos en la rectificación	Evita la asignación masiva (por ejemplo, cambiarse el rol o los puntos).
Bitácora encadenada con HMAC y llave propia	Los triggers protegen frente a la aplicación; la cadena protege frente a quien tiene el archivo.
Sesiones con token aleatorio y solo su SHA-256 en la base	Se pueden revocar, y una filtración de la base no entrega sesiones válidas.
Validar la sesión contra la base en cada operación	Un cambio de rol, una cuenta deshabilitada o un permiso suspendido rigen de inmediato.
API solo con Bearer; web con cookie SameSite=Strict + token CSRF	La cookie no sirve en la API y los formularios no se pueden enviar desde otro sitio.
SQLite, Flask y la biblioteca estándar	Las mismas herramientas de las actividades anteriores; sin servicios externos que no estén disponibles.

6.2 Integración con los módulos existentes

- El registro (`registrar_cliente`) crea los eventos de consentimiento; reemplaza la columna `consentimiento_analitica` de la Actividad 4.
- `guardar_comportamiento` (seudonimización de la Actividad 4) y `correos_para_envio_boletin` consultan `consentimiento.vigente`.
- La rectificación usa `validar_*` y el cifrado con contexto de `cripto.py` de la Actividad 2; la supresión reutiliza `suprimir_cliente` y la pasarela simulada.
- El decorador `@requiere_permiso` de la Actividad 4 ahora escribe en la bitácora encadenada, y la matriz `PERMISOS` suma los roles privacidad y seguridad.
- Las 26 pruebas de la Actividad 4 siguen pasando junto con las 47 nuevas.

6.3 Los controles no se pueden eludir

La web y la API no tienen reglas propias: llaman a las funciones de servicio, y cada una decide con `@requiere_permiso`. Por eso una solicitud directa al servidor recibe la misma respuesta que en la pantalla. La base también se defiende sola, con restricciones CHECK y triggers. La tabla siguiente muestra intentos reales por la API y la web con sus códigos de respuesta, y la Figura 19 los intentos directos en la base.

Tabla 18. Intentos de eludir los controles por la API y la web (evidencia/ev_act5_elusion.txt).

Intento	Petición	Código	Respuesta
login de Carla (API)	POST /api/v1/sesiones	200	Sesión creada (token)
login de marketing (API)	POST /api/v1/sesiones	200	Sesión creada (token)
sin token	GET /api/v1/consentimientos	401	Se requiere iniciar sesión
token inventado	GET /api/v1/consentimientos	401	Se requiere iniciar sesión
Carla lee sus propios datos	GET /api/v1/clientes/3	200	Sus propios datos
Carla pide los datos de Beto (IDOR)	GET /api/v1/clientes/2	403	Acceso denegado
Carla lee la auditoría	GET /api/v1/auditoria	403	Acceso denegado
marketing lee la auditoría	GET /api/v1/auditoria	403	Acceso denegado
marketing ejecuta contención	POST /api/v1/contencion	403	Acceso denegado
Carla rectifica con campo extra 'rol'	POST /api/v1/derechos	400	Solo se pueden rectificar: nombre, teléfono, dirección y correo
Carla otorga con versión no numérica	POST /api/v1/consentimientos/boletin	400	Se esperaba un valor numérico
cookie de sesión usada en la API	GET /api/v1/consentimientos	401	Se requiere iniciar sesión
formulario web sin token CSRF	POST /consentimientos/boletin/otorgar	400	Formulario rechazado (falta el token CSRF)
cierre de sesión	DELETE /api/v1/sesiones	204	Sesión cerrada
token después de cerrar sesión	GET /api/v1/consentimientos	401	Se requiere iniciar sesión

```
Cambios directos en la base (triggers y restricciones):
  UPDATE administradores SET rol='superadmin' WHERE id=2     -> IntegrityError: CHECK constraint failed: rol IN
('administrador','soporte','logistica','marketing','privacidad','seguridad')
  UPDATE consentimientos SET version=99                      -> IntegrityError: el historial de consentimientos no se
modifica
  DELETE FROM auditoria                                      -> IntegrityError: auditoria es inmutable
  UPDATE solicitudes_derechos SET estado='aprobada'          -> IntegrityError: CHECK constraint failed: estado IN
('recibida','verificada','en_evaluacion','ejecutada','rechazada','cerrada')
```

Figura 19. Cambios directos en la base: las restricciones CHECK y los triggers los rechazan (evidencia/ev_act5_elusion.txt).

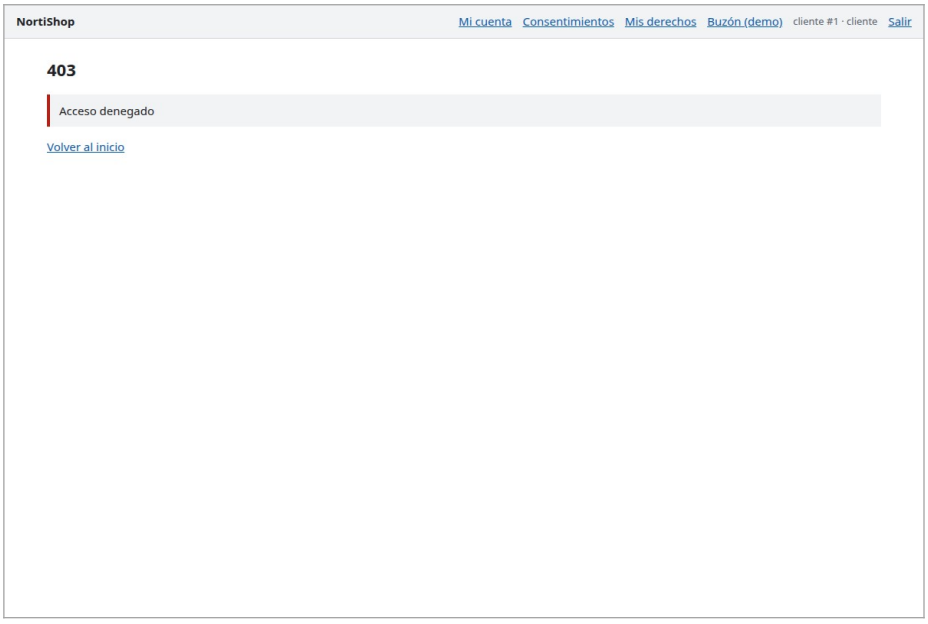


Figura 20. Una clienta que entra a /seguridad recibe 403.

6.4 Limitaciones

- **Correo simulado:** no hay servidor SMTP; el buzón en memoria permite probar la lógica completa. En producción se reemplaza `notificador.enviar` por un proveedor de correo.
- **Un solo servidor:** el límite de intentos por IP y el buzón viven en memoria; con varios servidores irían a un almacenamiento compartido.
- **Llaves en el .env:** en producción deberían estar en un gestor de secretos o HSM, separadas del servidor de la base.
- **Sin MFA para el personal:** queda como medida preventiva recomendada; el plan la propone tras un incidente.
- **Respaldos:** la lista de supresión está implementada, pero la rotación de respaldos depende de la infraestructura del hosting.
- **Ancla de la bitácora:** se genera, pero guardarla fuera del servidor es un procedimiento manual.

7. Evidencias de pruebas

Las pruebas usan una base temporal y datos ficticios. Se ejecutan con `python -m unittest pruebas_seguridad pruebas_actividad5 -v`. La salida completa está en `evidencia/ev_act5_pruebas.txt`.

Tabla 19. Resultado de las pruebas.

Grupo	Pruebas	Correctas
Consentimiento	11	11
Derechos	13	13
Auditoría	6	6
Detección e incidentes	7	7
Elusión (web, API y base)	10	10
Actividad 4 (regresión)	26	26
Total	73	73

Tabla 20. Casos de prueba de la Actividad 5.

Id	Qué comprueba	Resultado
C01	Registro registra solo las finalidades marcadas	OK
C02	Una finalidad no habilita otra	OK
C03	Evento guarda fecha version y estado	OK
C04	Revocar analitica borra el comportamiento y lo impide	OK
C05	Revocar boletin saca el correo de la campana	OK
C06	Version del texto y cambio material	OK
C07	Finalidad contractual no se consiente	OK
C08	Historial no se modifica ni se borra	OK
C09	Cada cliente ve solo sus consentimientos	OK
C10	Registro exige declarar mayoria de edad	OK
C11	Baja del boletin con el enlace	OK
D01	Recepcion con reautenticacion y codigo al correo	OK
D02	Tres codigos incorrectos rechazan la solicitud	OK
D03	Codigo vencido no sirve	OK
D03b	Reenvio de codigo limitado	OK
D04	Exportacion estructurada sin datos internos ni de terceros	OK
D05	Solicitudes ajenas y roles sin permiso	OK
D06	Rectificacion solo campos permitidos y validos	OK
D07	Rectificacion actualiza cuenta y pedidos no despachados	OK
D08	Cambio de correo con segundo codigo y recifrado	OK
D09	Supresion condiciones y ejecucion	OK
D10	Rechazo fundamentado y una sola prorroga	OK
D11	Bandeja de privacidad sin datos personales	OK
D12	Supresiones se reaplican al restaurar un respaldo	OK
A01	Operaciones relevantes quedan registradas sin datos personales	OK
A02	Cadena detecta alteraciones aunque se quiten los triggers	OK
A03	Borrar una fila intermedia rompe la cadena	OK
A04	Ip truncada y canal	OK
A05	Solo administrador y seguridad leen la bitacora	OK
A06	Purga segura solo de lo vencido y la cadena sigue verificable	OK
I01	Fuerza bruta y relleno de credenciales sin duplicar	OK

Id	Qué comprueba	Resultado
I02	Consulta masiva de datos personales	OK
I03	Exportaciones anomalas y denegaciones repetidas	OK
I04	Contencion deshabilitar cuenta y suspender permiso	OK
I05	Preservar evidencia antes de contener	OK
I06	Evaluacion notificacion y cierre	OK
I07	Rotacion de llave y comprobaciones de recuperacion	OK
W01	Sin token token inventado o cerrado	OK
W02	Idor datos de otro cliente	OK
W03	Rol sin permiso en la api	OK
W04	Asignacion masiva en rectificacion	OK
W05	Flujo completo por api	OK
W06	La cookie no sirve en la api y la web exige csrf	OK
W07	Rol cambiado o forjado no sirve	OK
W08	Limite de intentos y cabeceras de seguridad	OK
W09	La base rechaza cambios directos	OK
W10	Errores no revelan valores	OK

Además de las pruebas, `evidencia_act5.py` ejecuta las operaciones de punta a punta y guarda su salida en `evidencia/ev_act5_*.txt` (citadas en las secciones 2 a 6), y `verificar_secretos.py` comprueba que las llaves no estén en el repositorio, que la base tenga permisos 600, que no haya datos en claro y que la bitácora esté íntegra (15/15).

```
test_A06_purga_segura_solo_de_lo_vencido_y_la_cadena_sigue_verificable
(pruebas_actividad5.PruebaPurgaAuditoria.test_A06_purga_segura_solo_de_lo_vencido_y_la_cadena_sigue_verificable) ...
ok
test_A01_operaciones_relevantes_quedan_registradas_sin_datos_personales
(pruebas_actividad5.PruebasAuditoria.test_A01_operaciones_relevantes_quedan_registradas_sin_datos_personales) ... ok
test_A02_cadena_detecta_alteraciones_aunque_se_quiten_los_triggers
(pruebas_actividad5.PruebasAuditoria.test_A02_cadena_detecta_alteraciones_aunque_se_quiten_los_triggers) ... ok
test_A03_borrar_una_fila_intermedia_rompe_la_cadena
(pruebas_actividad5.PruebasAuditoria.test_A03_borrar_una_fila_intermedia_rompe_la_cadena) ... ok
test_A04_ip_truncada_y_canal (pruebas_actividad5.PruebasAuditoria.test_A04_ip_truncada_y_canal) ... ok
test_A05_solo_administrador_y_seguridad_leen_la_bitacora
(pruebas_actividad5.PruebasAuditoria.test_A05_solo_administrador_y_seguridad_leen_la_bitacora) ... ok
test_C01_registro_registra_solo_las_finalidades_marcadas
(pruebas_actividad5.PruebasConsentimiento.test_C01_registro_registra_solo_las_finalidades_marcadas) ... ok
test_C02_una_finalidad_no_habilita_otra
(pruebas_actividad5.PruebasConsentimiento.test_C02_una_finalidad_no_habilita_otra) ... ok
...
----------------------------------------------------------------------
Ran 73 tests in 2.458s

OK
```

Figura 21. Extracto de la ejecución de las pruebas (evidencia/ev_act5_pruebas.txt).

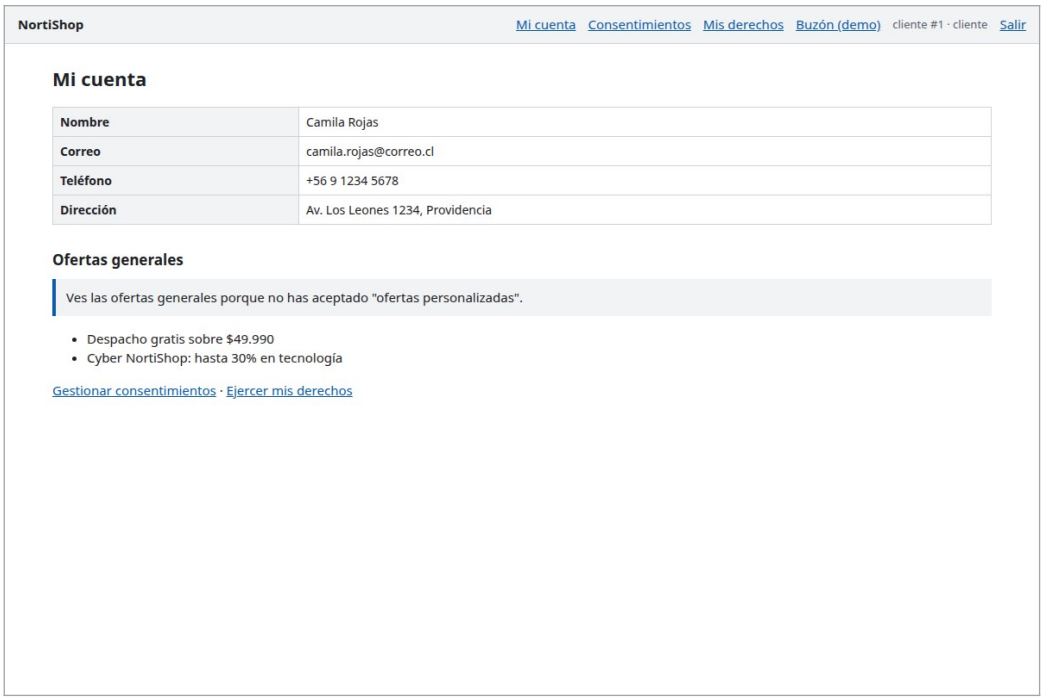


Figura 22. Mi cuenta: datos de la clienta descifrados solo para ella.

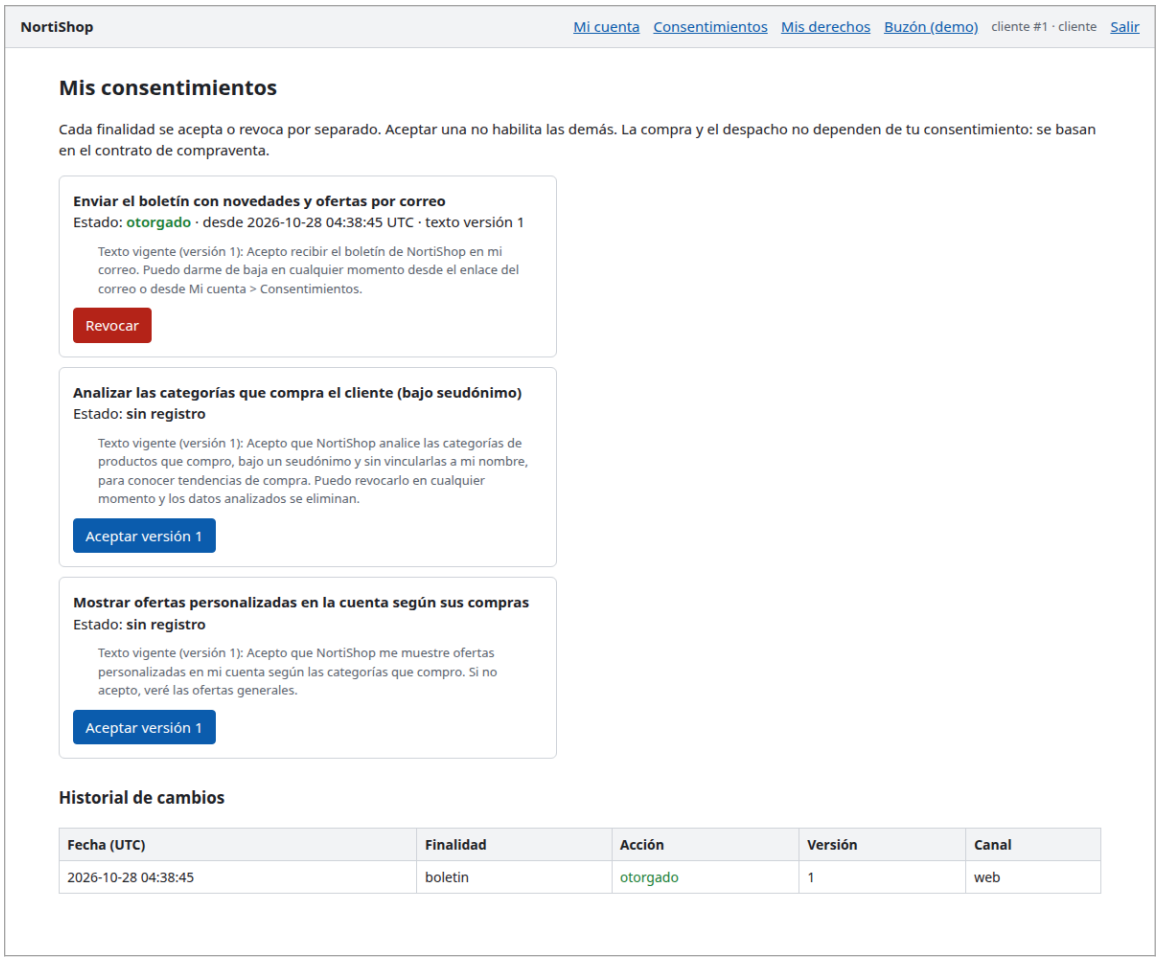


Figura 23. Consentimientos al iniciar el recorrido.

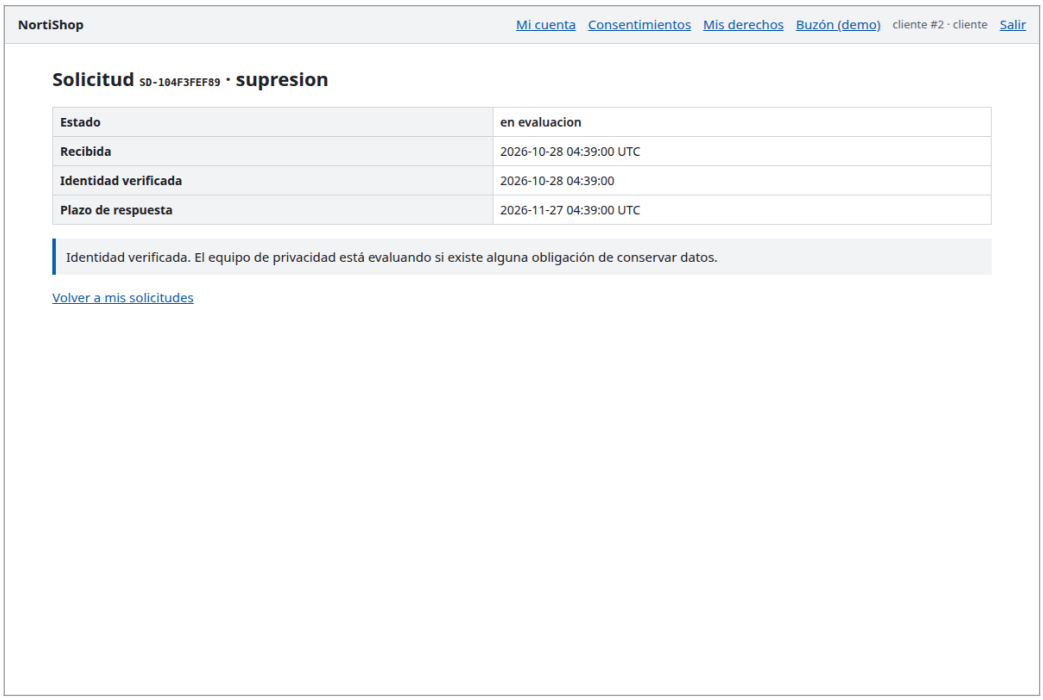


Figura 24. Solicitud de supresión verificada, en evaluación por privacidad.

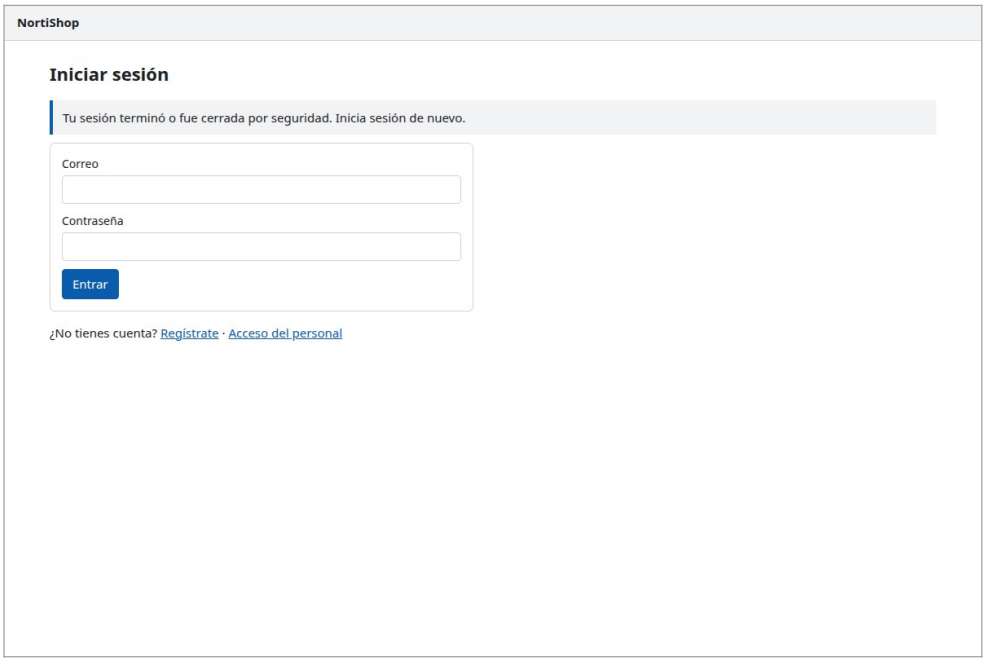


Figura 25. Tras la supresión, la sesión del cliente ya no existe.

8. Justificación técnica final

8.1 Principales decisiones

Elegimos poner los controles en la capa de servicio, y no en las pantallas, para que la web, la API y cualquier interfaz futura los hereden. La base de datos agrega una segunda barrera (CHECK y triggers) para quien llegue por fuera de la aplicación, y la cadena HMAC una tercera, para quien tenga el archivo. Para cada dato preferimos guardar lo mínimo: el estado del consentimiento se calcula, el código de verificación se guarda como HMAC, la bitácora usa ids y la IP se trunca. La verificación de identidad se apoya en lo que la persona ya tiene (contraseña y correo), en vez de pedirle documentos.

8.2 Riesgos mitigados

Tabla 21. Riesgos y controles.

Riesgo	Control
Usar datos para fines no consentidos	Consentimiento por finalidad exacta, con versión; revocación con efecto inmediato
Entregar datos a un impostor	Contraseña + código al correo; segundo código al cambiar el correo; alerta de cambio de correo y exportación
Exportar datos de terceros o internos	Exportación construida campo a campo, sin hashes, tokens ni datos de otros
Cambiar campos no permitidos	Lista blanca y validación de cada campo
Datos que siguen usándose tras la supresión	Borrado en todos los módulos, sesiones revocadas, lista de supresión para respaldos
Borrar o alterar las huellas de un ataque	Triggers, cadena HMAC con llave propia, ancla y preservación de evidencia
Bitácora que filtra datos personales	Solo ids, nombres de campos e IP truncada
Abuso del personal	Mínimo privilegio, regla de consulta masiva, suspensión de permisos
Saltarse la interfaz	Mismas funciones para web y API; Bearer en la API; CSRF en la web; restricciones en la base
Notificar tarde o sin criterio	Evaluación registrada, borrador con los 7 contenidos y condiciones de cierre

8.3 Limitaciones y trabajo pendiente

Las limitaciones están en la sección 6.4. Las más importantes para pasar a producción son: un proveedor de correo real, guardar las llaves en un gestor de secretos, MFA para el personal y guardar el ancla de la bitácora en otro sistema. Si se aprueba la postergación del boletín 18.623-07, el diseño no cambia: solo se mueve la fecha desde la que la Agencia puede fiscalizar.

9. Referencias

- Ley N° 19.628, sobre protección de la vida privada, modificada por la Ley N° 21.719 (2024), que regula la protección y el tratamiento de los datos personales y crea la Agencia de Protección de Datos Personales. Biblioteca del Congreso Nacional, idNorma 1209272. Artículos 5°, 7°, 9°, 11, 12, 14 quinquies, 14 sexies, 16 quáter, 50 y primero transitorio.
- Senado de Chile. Boletín N° 18.623-07, proyecto que modifica la Ley N° 21.719. Estado de tramitación consultado el 28/10/2026.
- Ley N° 21.663, Ley Marco de Ciberseguridad. Biblioteca del Congreso Nacional, idNorma 1202434. Artículos 4° y 9°.
- Decreto Ley N° 830, Código Tributario, artículo 200.
- Grupo NortiShop. Actividad N°1, Actividad N°2 (Items I y II), Inventario y clasificación de datos personales e Informe técnico de la Actividad N°4. Repositorio github.com/m1lvn/nortishop-seguridad.

Anexo A. Cumplimiento de la pauta

Tabla 22. Entregables y requisitos de la pauta.

Requisito	Dónde se cubre
Documento de diseño del módulo de consentimiento	Sección 2
Consentimiento independiente por finalidad; no se asume para otras	2.1, 2.5; prueba C02
Fecha y hora, finalidad, versión del texto y estado	2.2, 2.3; prueba C03
Consultar el historial y sus cambios de estado	2.2, Figura 2; prueba C08
Revocar y registrar fecha y hora; efecto en los procesos	2.4; pruebas C04, C05, C11
Trazabilidad sin datos innecesarios	2.6
Flujo para menores o por qué no aplica	2.7; prueba C10
Modelo de datos, pantallas y pruebas del consentimiento	2.2, 2.8, Figuras 1-3
Documento de ejercicio de derechos	Sección 3
Acceso y portabilidad: copia, formato, identidad, sin terceros	3.2, 3.3; pruebas D01-D04
Rectificación: validaciones, registro, otros módulos	3.4; pruebas D06-D08
Supresión: condiciones, conservación, copias, sistemas relacionados	3.5; pruebas D09, D12
Verificación de identidad proporcional	3.2
Flujo con recepción, verificación, evaluación, respuesta y cierre, con fechas	3.1, Figura 7; prueba D10
Diseño del registro de auditoría	Sección 4
Eventos, atributos, protección, quién consulta, conservación	4.1, 4.2, 4.4, 4.5, 4.6
Información que no se registra	4.3; prueba A01
Justificación trazabilidad / minimización	4.7
Ejemplos de eventos reales	4.8
Plan de respuesta a incidentes	Sección 5
Preparación: responsables, canales, recursos	5.1
Detección y análisis: criterios, gravedad, alerta / sospechoso / incidente	5.2; pruebas I01-I03
Contención sin destruir evidencia	5.3; pruebas I04, I05
Erradicación, recuperación y comprobaciones	5.4; prueba I07
Notificación: criterios, quién autoriza, plazos según la normativa, 7 contenidos	5.5; prueba I06
Lecciones aprendidas	5.6
Responsables por fase, escalamiento y cierre	5.7, 5.8
Código fuente integrado con los hitos anteriores	Sección 6; repositorio (rama actividad5)
Justificación de la implementación	6.1
Controles no eludibles por solicitudes directas al servidor o la base	6.3; pruebas W01-W10
Limitaciones de infraestructura documentadas	6.4
Evidencias de pruebas	Sección 7 y carpeta evidencia/
Justificación técnica final	Sección 8